

健保資料庫案後的健康資料再利用法制*

—— 歐盟法制及英國經驗對我國之啟發

翁逸泓**

摘要

本文之目的在於理解健康資料治理法制上應當蘊含之論理，並分析為何我國不應該揚棄現行所繼受之歐盟個資保護與資料法制模式。

歐盟資料法制模式以貌似複雜，但實質上友善的管制方式，在綿密的體系架構包括以資料治理法與健康資料空間規則提案等，處理在健康資料研究的權利衡平問題。就英國法而言，實際問題之癥結在於政府與民眾間就資訊隱私和安全性與資料利用透明度和可控性等議題，未能建立足夠之「信任」關係，因此嘗試提出TRE作為解方。

本文認為，我國現行法律僅透過傳統上區分不同學術研究和不同公益重要性的方式來衡平個人資料權利與公共利益，無法真正地反映人民個資權利可能受到的風險，也難以符合比例原則的實質判斷。最後，就臺灣未來資料治理法制而言，則須有關機關與資料控

* 投稿日：2023年3月24日；接受刊登日：2024年8月19日。〔責任校對：鄭竣能〕。

本文為作者執行國科會研究計畫（NSTC 113-2410-H-128-009-MY2及MOST-111-2410-H-128-003-MY2）之研究成果。作者衷心地感謝諸位審查人與出版委員會之具體評論與建議，這些寶貴的意見對本文以及對於作者本身都有極大幫助與鼓勵，惟文責當由作者自負。

** 世新大學法律學院教授。

穩定網址：<https://publication.iias.sinica.edu.tw/42718052.pdf>。



制人能承擔信任擔保責任、有效監督管理個資應用行為，並有更佳之公眾溝通。

關鍵詞：資料治理、個人資料保護、健保資料庫、歐盟一般資料保護規則、隱私權、可信任研究環境。

目次

壹、前言：健保資料庫案，然後呢？	一、英國的資料法制與健康資料加值應用經驗：信任的形塑
貳、歐盟一般資料與健康資料之再利用法制	二、英國資料法制的「轉向」？
一、不同的資料法制模式與科研發展	肆、臺灣健康資料再利用法制
二、歐盟資料治理法制模式：對健康科學研究的複雜資料治理框架	一、健保資料庫案判決所給的重點與可能的誤區
參、英國的失敗經驗、教訓以及新方向	二、未來有關資料驅動科研之再利用法制
	伍、結論

壹、前言：健保資料庫案，然後呢？

健保資料庫案在爭訟逾十年後，在2022年憲法法庭終以111年憲判字第13號判決作為一個階段性的休止符。綜觀健保資料庫案之伊始，乃源於聲請人認衛生福利部中央健康保險署（以下簡稱：健保署）對於健保資料庫內之資料用於健保業務以外之目的，而該等資料卻包含受憲法隱私權保障之個人健保資料，認為是對於原始蒐集目的外之利用，有違法之情事，爰提起相關救濟程序。究其主要爭議之所在，係針對健保署將含個人健保資料之資料，交予健保署以外之單位（原國家衛生研究院，後為健保署設置之全民健康保險

保險人資訊整合應用服務中心，以及交予衛生福利部之衛生福利資料科學中心設置資料庫），並對外提供學術研究此一超越原始蒐集健保資料目的（辦理健保業務）之行為¹。憲法法庭於系爭判決中雖認為個人資料保護法（以下簡稱：個資法）本身並未違憲（主文一），但是，無論從組織保障上因缺乏所有個資（再）利用行為獨立監督防護機制而有違憲之虞、健保署將健保資料庫中個資為目的外利用之行為欠缺相關明確法律而違反法律保留原則、以及由相關法制整體觀察，健保署系爭行為欠缺當事人得請求停止利用之相關規定等，均具瑕疵（主文二至四）。基於此，在整個健保資料庫案中除了個資法本身以外，相關的個資（再）利用行為至少在組織與程序保障以及實質權利保護的法制上，都在本案判決後需為一定之更動或新增。

在本案判決兩年後的2024年8月，行政院2024生技產業策略諮議委員會議（Bio Taiwan Committee, BTC）尤其為了因應AI等創新科技帶來跨域應用發展之新契機，仍認為個人之健康資料有極大的利用可能性與益處，因此提出包括結合民間力量及各大公立醫學中心成立健康數據（資料）服務公司、加速建置接軌國際標準之醫療資訊系統平台，以及推動去連結後的數據（資料）應用於產業，平衡產業需求和隱私保護等綜整建議²。由此可見，對於個人健康資料之（再）利用仍為生醫產、學、研界之重大企盼。不過法律人或許要追問的是，相關的個資（再）利用法制，是否是萬事俱備下，所依然欠缺的那個「東風」？

本文認為，整體以觀，這個漫長的訴訟過程所能帶來的思考點或許有以下幾個：

¹ 憲法法庭111年憲判字第13號判決段12參照。

² 國家科學及技術委員會，行政院2024 BTC會議圓滿落幕 政策助力推升生醫競爭力，2024年8月28日，<https://www.nstc.gov.tw/folksonomy/detail/bc9fccf7-b1f6-48b1-ba8a-377a20a60d52?l=ch>（最後瀏覽日：2024年10月7日）。

首先，以數位健康資料應用領域的資訊隱私及個資保護爭議來說，既然健保資料庫案能在臺灣持續地爭訟長達十年，因此絕對不會還是一個多新鮮的議題。數位健康資料應用包含了多種不同的應用場域，例如遠距醫療與照護、臨床資訊系統、整合性資訊架構、傳染性疾病與公共衛生通報系統、手機健康資訊應用程式、個人化穿戴式健康資料系統，以及健康資料在大數據、物聯網、和人工智慧等領域的應用，這些都可能涉及到個人健康資料的處理和分享行為，並可能帶來個資權利侵害風險³。近年來，由於網路的普及和資料為王的趨勢，數位健康資料應用的場域和機會快速增加。在權利的平衡問題上，需要更加重視包括個資當事人等利害關係人對於資料權利之應用與獲益面向。在這些問題中，不同的權利可能相互競合，除了個人的資料權利以外，還包括了「享受科學研究進展與應用利益之權利」⁴，或甚至可能蘊含資料經濟伴隨的財產權。所謂「享受科學研究進展與應用利益之權利」，在不同的國際人權文件當中有不同之規範內涵，例如在世界人權宣言（Universal Declaration of Human Rights）中，指的是每個人都有自由地參與科學的進步以及分享其利益之權利⁵；在經濟社會文化權利國際公約（The International Covenant on Economic, Social and Cultural Rights）第15條第1項第b款中，則為每個人都有享受科學進步及其應用所帶來的利益之權利⁶；另外，在美洲人權與義務宣言（American Declaration of the Rights and Duties of Man）第13條則較清楚呈現為每個人都有參與知識進步，特別是科學發現所帶來利益之權利⁷。

3 Joseph L. Hall & Deven McGraw, *For Telehealth to Succeed, Privacy and Security Risks Must Be Identified and Addressed*, 33 HEALTH AFF. 216, 216-21 (2014).

4 聯合國世界人權宣言第27條、經濟社會文化權利國際公約第15條，以及公民與政治權利國際公約及經濟社會文化權利國際公約施行法第2條參照。

5 原文為：“Everyone has the right freely ... to share in scientific advancement and its benefits.”

6 原文為：“...To enjoy the benefits of scientific progress and its applications”.

7 原文為：“Every person has the right to take part in the cultural life of the community,

因此在保障範圍上，除進行科學研究參與外，亦保障個人享受其應用利益之權利。然則，如果單純只觀察相關國際人權文件，似未直接地表明能利用個資之特定方式進行科學研究並享受相關應用所得利益之旨。不過，在數位時代科技應用對隱私權造成巨大衝擊的當下，聯合國人權理事會年度報告中便特別指出，在人工智慧應用領域中，各國之資料隱私框架應該考慮其與人工智慧應用相關的新威脅，立法者尤其也應該特別考量強化個人權利之保障⁸。該份報告亦特別就國家和企業廣泛使用的人工智慧，包括個人資料檔案製作、自動決策和機器學習技術，對隱私權及相關權利的影響等提出意見，並對該等挑戰提出包括國家和企業在設計和實施防止和減少有害結果以及促進充分享受人工智慧所帶來的利益之保障措施的對應建議⁹。

承上，現今在法制上、論理上以及實際應用場域上，隱私權內涵以及保障之重心已從古典的資訊隱私保護防衛觀點（例如空間隱私權較為重視的獨處權利），漸次地移動至衡平資訊自主權與「特別重要公益」¹⁰，甚至是資料權利應用觀點¹¹，因此或許開始著手考量關於資料整體生態週期活動之治理法制，此其時矣。

第三，隨著積極推動民眾與企業對政府開放資料作創新加值應用，公部門資料開放也促使各種商業應用更加多元和活躍。基於這個脈絡，經常有論者認為健保資料庫的開放不僅使公務機關能夠在

to enjoy the arts, and to participate in the benefits that result from intellectual progress, especially scientific discoveries”.

8 Hum. Rts. Council, Rep. of the U.N. High Commissioner for Hum. Rts.: The Right to Privacy in the Digital Age, para. 42, U.N. Doc. A/HRC/48/31 (Sept. 13, 2021), <https://documents-dds-ny.un.org/doc/UNDOC/GEN/G21/249/21/PDF/G2124921.pdf?OpenElement>.

9 *Id.* at 1.

10 憲法法庭111年憲判字第13號判決段48、51、56-57參照。

11 Ari Ezra Waldman, *Privacy as Trust: Sharing Personal Information in a Networked World*, 69 U. MIAMI L. REV. 559, 567-90 (2015).

政策上推動科學研究成果，而且未來還有機會在產業方面進行商業應用，從而形成一定規模的資料經濟。不過，亦有學者認為，在這個特定目的以外的多元加值應用的資料活動中，無論是政府還是第三方的資料利用者，對於政府持有資料庫的利用，仍然應該遵循相互尊重和信任的原則¹²。具體而言，如果要讓個資當事人盡可能地依照其資訊自決權自主地交付其個人資料給特定的資料利用人，那麼這些特定的資料利用人應該值得個資當事人的信任。這個信任的基礎不僅是在社會實踐層面的互動問題上¹³，還包括合理且適當的擔保責任和政府監管責任。唯有如此，個資當事人、資料利用人和政府機關等資料應用行為的各主體之間才能置於同一個架構之下，法制上呈現緊密的連結關係，進而產生信任。

以前述的三個觀察點來說，邏輯上基於其相互關係所要問的問題或許會是：

1. 如重視資料權利之賦權，亦即將資料權利之重心延伸至「利害關係人對於資料權利之應用與獲益」，是否即意謂著必須棄守「歐盟資料法制模式」？

此時判斷是否應放棄「歐盟資料法制模式」之癥結點，毋寧在於為什麼應該要棄守該法制模式？換言之，如果棄守該法制模式，是否能對於資料當事人權利以及民主社會的整體公共利益，帶來更加優勢？

2. 如果開放政府資料與多元活化資料利用之核心在於建立信任基礎，那麼這個基礎是否能在「歐盟資料法制模式」中尋得？

12 *Id.* at 590-91; see Penny Duquenoy et al., *Patients, Trust and Ethics in Information Privacy in eHealth*, in *eHEALTH: LEGAL, ETHICAL AND GOVERNANCE CHALLENGES* 275, 275-95 (Carlisle George et al. eds., 2013).

13 Waldman, *supra* note 11, 601-16.

在此二爭點間，本文認為可以歐盟資料法制模式為論述之經緯，這是因為歐盟資料法制之出發點厥為對於個人基本權利之保護¹⁴，而其法制進展的相關文獻與規範內容中，也一再地提及信任作為包括資料再利用行為的資料治理之關鍵所在。本文進一步認為，如果要思索「歐盟資料法制模式」是否適合在健保資料庫案後，繼續作為我國資料法制模式之繼受來源，則英國之資料法制模式或許值得探究：

1. 英國目前的資料法模式仍然受到歐盟資料法制規範的深刻影響，例如，2018年英國的資料保護法（Data Protection Act 2018, DPA 2018）是其仍然作為歐盟會員國時期之規範，而在脫離歐盟後，為了獲得歐盟一般資料保護法（General Data Protection Regulation, GDPR）的適足性而推出鏡像的UK GDPR（United Kingdom General Data Protection Regulation）。英國政府近年來在政策與法制層面，似乎也在尋求新的資料再利用乃至於整體資料治理的法制方向。就此，在憲法法庭111年憲判字第13號判決的訴訟過程中，關係機關健保署亦提出英國之相關修法方向，「深值我國法學界重視」¹⁵。
2. 在健保資料庫的資料應用方面，英國與我國一樣都具有全民健康保險制度並受歐盟個資保護法制所約束。但是，英國在實際的健康資料應用推行政策上，曾經有過失敗的經驗，也有意圖再起的嘗試，則或許可以提供我國反思與學習的經驗¹⁶。

14 歐盟基本權利憲章（Charter of Fundamental Rights of the European Union）第7、8條參照。

15 憲法法庭111年憲判字第13號判決相對人答辯書、補充答辯書，衛生福利部中央健康保險署1110503函暨法規範憲法審查補充答辯書，頁10。

16 對英國健保資料之再利用經驗分析，參：翁逸泓，開放全民電子健康資料加值應用之個資保護問題——以英國經驗為例，月旦法學雜誌，285期，頁144-173。

最後，除就系爭憲法法庭判決本身評論，本文之目的更強調理解健康資料再利用法制上應當蘊含之論理，因此除了在實務上歐盟資料法制因為已成國際趨勢而不應無視以外，本文則嘗試探索我國資料法制為何不應該揚棄現行所繼受之歐盟個資保護與資料法制模式，並探求堅守該模式的學理基礎。

本文之研究目的以健康資料之再利用法制等資料治理規範為核心，探究健康資料於科學研究之法制框架。此間雖然歐盟現階段對於健康資料之再利用等治理內涵提出歐盟健康資料空間規則提案（Proposal for Regulation on the European Health Data Space）¹⁷，然由於GDPR當中對於一般性資料於科學研究當中有其衡平規範（第89條），而在歐洲健康資料空間規則（European Health Data Space, EHDS）尚未施行前，健康資料之應用法制本有各會員國內國法律體系落實GDPR之相關實務，因此在行文架構上，本文於第貳部分分析歐盟資料法制對於科學研究管制之框架，首先分析GDPR對於一般性個人資料應用於科學研究之管制問題，其後則進入個別之健康資料應用領域比較EHDS，以綜觀歐盟健康資料之再利用規範。

於第參部分觀察英國對於健康資料進行加值再利用之可能法制趨勢後，由於健康資料治理之概念包含對於政府持有健康資料之再利用，本文在第肆部分將更聚焦在臺灣之健保資料庫案中關於健保

（2019年）；何之行，英國生醫健康資料之整合應用與資料治理規範，月旦法學雜誌，331期，頁9-23（2022年）。

¹⁷ *Proposal for a Regulation of the European Parliament and of the Council on the European Health Data Space*, COM (2022) 197 final (May 3, 2022) [hereinafter *European Health Data Space proposal*]. 又，本文接受刊登後，EHDS在2025年3月5日於官方公報正式公告，2025年3月26日生效，即Regulation (EU) 2025/327 of the European Parliament and of the Council of 11 February 2025 on the European Health Data Space and amending Directive 2011/24/EU and Regulation (EU) 2024/2847 (Text with EEA relevance), 2025 O.J. (L 2025/327) [hereinafter *European Health Data Space*]。惟此規則之施行尚需歐盟執委會陸續制定相關施行細則，而至2027年3月方為制定相關施行細則之最後期限。其後從2029年3月開始，EHDS方分梯次適用其不同健康資料之領域，併此敘明。

資料之目的外利用的相關規範，回到我國健保資料庫案本身，提出未來資料驅動型態科研活動之資料法制芻議。

貳、歐盟一般資料與健康資料之再利用法制

一、不同的資料法制模式與科研發展

由於我國個資法乃繼受歐盟資料保護法制模式，因此如若企圖更進一步地發展有關資料利用與共享之資料治理法制，歐盟的資料法制理當是一個相當重要的參考座標。不過大約從2018年以降，如果在媒體上以及相關學術研究場域上看到關於歐盟GDPR之報導或研究，大多數的時候其會被冠以「有『史上最嚴格個資法』之稱的GDPR」作為標題或是開場白¹⁸。細究其之所以如此被形容的原因，或許一個重要的理由即在於GDPR賦予了更多的個資當事人資料權利，例如較受到矚目的被遺忘權（the right to be forgotten）¹⁹使得資料控制人的義務與責任增加，同時也為個資的加值應用增加了成本。再者，於對歐盟各會員國健康資料應用研究者實證訪談的研究當中，亦指出就可識別和個體層次的資料而言，GDPR會因為對於去識別化之嚴格認定，而被視為一個障礙：倘若個資處理侷限於地區、性別、年齡組和國際疾病分類（International Classification of Diseases, ICD）代碼等範疇的健康資料時，尤其是在罕見疾病類型當中的樣本可能過少，則因為一切的去識別化都幾乎會毫無意義而可重新識別，造成與類似個體層次之資料進行工作變得複雜²⁰。另就健康資

18 例如參：胡林，史上最嚴個資法GDPR上路，能力雜誌，750期，頁17-19（2018年）。

19 Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation), art. 17, 2016 O.J. (L 119) 1, 43-44 [hereinafter GDPR].

20 Jakov Vukovic et al., *Enablers and Barriers to the Secondary Use of Health Data in*

料跨境傳輸處理言，即便是GDPR已經是歐盟規則（Regulation）之層級，但是由於其仍保留部分會員國法體系豁免之空間，因此在不同會員國對GDPR的不同解釋和實施以及對它的不清晰理解，也被視為在歐洲跨境健康資料交換的障礙²¹。基於此，或許有認為GDPR此等個資法制於需要大量個資作為研究驅動來源的生物醫學與公共衛生研究來說，顯得相對嚴格者。

承上，如若將歐盟的資料法制模式認為是相對嚴格，尤其是認為關於個資之再利用往往受到資料保護規範的過度「箝制」者，可能會順著這個脈絡去想像臺灣或許在法制繼受上容有更易之需求——畢竟，數位科技應用與生醫研究乃是臺灣重要發展政策趨勢與學術研究上之顯學。此間如從資料利用法制的模式以觀，除歐盟資料法制模式外，國際上亦有較著重於自由市場價值與業者自律的美國數位管制／資料法制模式²²，或得為參考之選項，而使對於健康科學研究之管制獲得一定程度之「鬆綁」。

（一）美國資料法制模式與健康資料加值應用

一般而言，美國的資料法制通常被認為較重視創新和企業自由，對商業應用和資料開放的限制較少。究其所以，當涉及到健康資料的特定目的外利用時，如果透過某種程度的去識別化處理可以達到無法識別特定個人或不具備獨特個人特徵的識別可能，則可能脫離個人資料法的保護範圍。因此，如果無法識別特定個人的判斷標準較為寬鬆，相對地，對於健康資料的目的外再利用範圍可能更廣泛。

Europe: General Data Protection Regulation Perspective, 80(115) ARCHIVES PUB. HEALTH 1, 7 (2022).

21 Agnese Bankava et al., *The Effect of GDPR on Secondary Use of Data Concerning Health in Research: Latvian Case in the European Context* (2020), https://www.apgads.lu.lv/fileadmin/user_upload/lu_portal/apgads/PDF/Juriskas-konferences/ISC-FLUL-7-2019/iscflul.7.2-16_Bankava_Buka_Mezinska_Barzdins.pdf.

22 ANU BRADFORD, *DIGITAL EMPIRES: THE GLOBAL BATTLE TO REGULATE TECHNOLOGY* 6-11 (2023).

比較法觀察上，如果從近日美國資料法制發展新猷，號稱「美國最嚴厲」²³的加州消費者隱私保護法（California Consumer Privacy Act, CCPA）以及其後「看起來沒有最嚴厲，只有更嚴厲」的加州隱私權利法（California Privacy Rights Act, CPRA²⁴）來看，其立法目的在於規範企業利用消費者個資之需求行為，因此焦點集中在消費者權利保護以及企業義務²⁵。

需注意者，相較於GDPR屬於具基本法性質之個資保護通常性規範，適用範圍同時包括公務機關及非公務機關，而與加州CPRA規範對於企業之蒐集、處理與利用消費者個資之行為有別。此間，CPRA只要求企業「合理地」刪除識別資料，並且匯總資料也不能「合理地」與個人或小群體關聯即可²⁶。再者，CPRA於相關企業組織必須已經實施了業務流程和技術保障措施，以防止其被重新識別之前提下，將無法合理識別特定消費者的資訊視為去識別化資訊²⁷。相對於此，由於GDPR對於個人資料之定義係適用於有關識別或可得識別當事人之任何資訊。依GDPR前言第26點，已假名化之個人資料，且可透過使用額外資訊而識別出當事人身分者，仍應被認為屬於可得識別之當事人的資訊，而落入GDPR適用範圍。如此，基於「兼顧消費者之個資保護與企業之資訊科技研發及消費者量身定做服務提供的利益權衡」，亦有學者認為不妨在未來我國個資保護相關之立法政策中，考量制定消費者個資保護專法，以適當地於非公務機關範圍排除對於公務機關之特定要求²⁸。

23 陳曉莉，美國最嚴厲的加州消費者隱私法案正式上路了，iThome，2020年1月3日，<https://www.ithome.com.tw/news/135154>（最後瀏覽日：2023年3月24日）。

24 CPRA係針對CCPA加以修正、強化消費者權利保障，並擴張了CCPA規範，其已然於2023年1月1日生效，並於2023年7月1日起發生全面之執法效力，效力並溯及2022年1月1日，而令2022年1月1日起所蒐集之個人資料均應遵守CPRA之規範。進一步的介紹，可參考：張陳弘，美國加州消費者隱私保護法制之最新發展與比較法啟示，當代法律，6期，頁24-39（2022年）。

25 張陳弘（註24），頁25-26、33-35。

26 CPRA § 1798.140(b) (2023).

27 CPRA § 1798.140(m) (2023).

28 張陳弘（註24），頁33。

不過，CPRA雖然規範消費者之領域，然主要仍適用於所有的個人資料，其中亦包括健康資料／敏感個人資料（sensitive personal information）之類別²⁹。亦即，企業僅可以包括：(1)為了確保個資利用之安全與完整（integrity）而合理必須且合比例之利用；(2)在未揭露個人身分、未建立個人剖繪資料之短期或短暫利用；(3)代表企業而提供服務；以及為驗證、維護或提升其企業服務或設備之品質或安全等企業目的之前提下，利用敏感之個人資料³⁰。企業如利用前述敏感個人資料以進一步推導出消費者個人特性，則個人可向企業要求限制敏感個資之利用與揭露。惟在適用上必須特別注意的是CPRA並未直接規定特定的個人健康資料之處理標準，亦無明確的個人健康資料再利用規則。相對地，GDPR對健康資料的處理則有較為明確的要求，本文後述之EHDS亦有關於健康資料再利用之特別規定。

再以健康資料應用個別領域來看，美國的「健康保險可攜與責任法」（Health Insurance Portability and Accountability Act, HIPAA）即規定安全港條款中去除全部的18個可識別因子（identifiers）、以統計方法去識別，或經專家決定之去識別程序後之健康資料具有微弱風險³¹，便非HIPAA所規管³²。

再者，GDPR關於明確同意（explicit consent）之要求，也令學者認為在美國健康個資傳輸至歐盟區域而進行HIPAA與GDPR調適時，必須要遵循相對嚴格的GDPR要件³³。細言之，學者指出由於GDPR的告知後同意要求採取明確同意之模式，因此使用已獲得美

29 CPRA § 1798.140(ae) (2023).

30 CPRA § 1798.121 (2023).

31 NAT'L INST. OF HEALTH, NIH PUBL'N NO. 03-5388, PROTECTING PERSONAL HEALTH INFORMATION IN RESEARCH: UNDERSTANDING THE HIPAA PRIVACY RULE 9-10 (2003).

32 45 C.F.R. § 164.514(b)(2)(i) and 45 C.F.R. § 164.514(b)(1) (Title 45 was last amended June 25, 2025).

33 Kelly Koeninger & John Conley, *International Health Data: How HIPAA Interacts with the EU GDPR*, 24(1) HEALTH L. CONNECTIONS 40, 42 (2020).

國之人體研究倫理委員會（Institutional Review Board, IRB）所依據具體個案批准的知情同意書，基於GDPR的嚴格標準幾乎不可能豁免，從而並不能保證符合GDPR的同意要求。也因為GDPR下的歐盟個資當事人權利遠遠超出了通常包含在美國知情同意文件中的內容，因此學者建議如果一個組織在歐盟蒐集健康資料是基於當事人同意而得，那麼便應該從GDPR的要求開始著手，並確保其美國的相關知情同意文件符合該標準³⁴。

基於前述GDPR和CCPA/CPRA以及HIPAA在資料去識別化以及當事人同意方面的不同要求，可推得在健康資料應用上GDPR要求之匿名化與當事人同意相對嚴格³⁵，也因此被認為美國的輕量管制方式，可能在資料加值應用與發展上更為有利³⁶。

但是，本文認為這可能非必完全地正確。這是因為：

1. 資料法制之適用範圍不同

需注意者，本文雖然以CCPA/CPRA以及HIPAA對照GDPR，然而必須特別說明者在於美國資料法制模式為分散式立法模型，與歐盟骨幹式建立一般性資料保護規範的GDPR模式容有不同。以CCPA/CPRA之本質言，僅為規範消費者權利及企業義務之消費者權利特別領域之資料法。Woodrow Hartzog與Neil M. Richards教授即指出即便CCPA/CPRA確實令企業有一定的義務，但較之GDPR，其範圍相對有限：即便CCPA/CPRA主要針對第三方廣告商和其他資料經紀商，對於基於公平資訊原則（Fair Information Principles,

³⁴ *Id.*

³⁵ 吳全峰、許慧瑩，健保資料目的外利用之法律爭議——從去識別化作業工具談起，月旦法學雜誌，272期，頁56-57（2018年）。

³⁶ 事實上，美國的網路與數位科技管制模式與政策在網路崛起的初期，即採行相對較為寬鬆的輕量管制方式。Kevin Werbach, *Introduction: An Endless Spiral of Connectivity?*, in *AFTER THE DIGITAL TORNADO: NETWORKS, ALGORITHMS, HUMANITY* 1, 1-4 (Kevin Werbach ed., 2020).

FIPs)的制度中概述的傳統「資料當事人權利」,CCPA/CPRA也僅只是實施部分而不是全部,其重點毋寧集中在企業透明化責任以及資料當事人對同意、控制和選擇概念之強化³⁷。因此在資料再利用行為法制之建構上,當有資料外溢至其他個別領域時,相關規範即可能無法覆蓋。

2. 履行對個資當事人知情權之責任成本較高

HIPAA規範了在沒有組織保障架構的機制性豁免(institutional waiver³⁸)情況下,為研究目的處理資料需要資料當事人的授權。換言之,在沒有個資當事人同意的情況下,如要以研究作為健康資料目的外利用之例外事由,就必須有包括IRB³⁹、HIPAA的「適用機構」(covered entities⁴⁰)隱私審查委員會或獨立委員會等組織保障機制的批准。在此種情況下,在HIPAA所指的資料利用協議(data use agreements)中所包括的健康資料雖然沒有完全去識別化,但已經刪除了某些直接識別因子⁴¹,且健康資料的當事人也可以對資料控制人要求其於提出時點前的6年期間內,曾揭露其健康資料之所有相關紀錄⁴²。學者對此認為,就揭露健康資料以進行研究目的的利用方式而言,需要確實記錄,這方面與GDPR的課責原則本質上並無差異。然而,由於HIPAA所規範的知情權是在結構化程度較低的資料環境中進行,必須蒐集證據並追蹤各種資料流,因

37 Woodrow Hartzog & Neil M. Richards, *Privacy's Constitutional Moment and the Limits of Data Protection*, 61 B.C. L. REV. 1687, 1711-12 (2020).

38 Michael J. Saks et al., *Advancing the Use of HIE Data for Research*, 52 ARIZ. ST. L.J. 145, 166, 176 (2020).

39 45 C.F.R. § 164.512(i)(1) (Title 45 was last amended June 25, 2025).

40 適用機構係指所有醫療相關機構,包括健康計畫、健康資料交換所,以及任何以電子形式傳輸與美國衛生及公共服務部部長在HIPAA交換標準下批准之健康資訊提供者,例如健康照護機構、健康計畫機構、公共衛生單位、雇主、保險公司、學校、大學或其他會交換健康資訊的機構等。

41 45 C.F.R. § 164.514(e) (Title 45 was last amended June 25, 2025).

42 45 C.F.R. § 164.528 (Title 45 was last amended June 25, 2025).

此實際上對於資料控制人的責任要求更加繁重⁴³，所需的經濟成本也相對可能更高。

3. 對為個資特定目的外而因科學研究利用個資之行為，可能並不實質友善

CCPA/CPRA在定義上對於目的外利用個資而「研究」採取相對狹義之範圍，僅限以公共利益為導向的研究行為，亦即「科學、系統之研究和觀察，包括符合公共利益並遵守所有其他適用的倫理和隱私法律，或為公共衛生領域的公共利益而進行研究的基礎研究或應用研究」⁴⁴。此時，在消費者與企業間的資料流通過程中，若企業基於其他目的自消費者蒐集的個人資料，在符合兼容性原則（compatibility⁴⁵）以及防止再識別技術、假名或去識別化等條件後，可基於研究目的進行目的外處理。然而，加州的個資保護法制為商業導向之研究，以所滿足利益的性質，而非所涉研究實體之本質為客觀定義⁴⁶，因此若研究符合公共利益，則可符合例外允許目的外利用之條件；反之，如涉及私人企業資助，則被認定為商業研究，不適用此等例外情況。學者認為，雖然加州的消費者隱私保護法提供更多的隱私保護，但此監管選擇可能反而阻礙因私人企業參與而涉及商業研究的創新研究類型⁴⁷。

又，美國資料法制在關於以科學研究為目的外利用個資之規範，在HIPAA本身並不對於追求商業利潤與公共利益為區別對待之

43 Giovanni Comandè & Giulia Schneider, *Differential Data Protection Regimes in Data-Driven Research: Why the GDPR is More Research-Friendly Than You Think*, 23 GERMAN L.J. 559, 565 (2022).

44 CCPA § 1798.140(s) (2018).

45 關於GDPR中對於「兼容」之概念，參：翁逸泓、李寧修（計畫主持人），歐盟國家個人資料保護法制因應GDPR施行之調適——以德國與英國為例，委託研究計畫結案報告（GRB系統編號：PG10805-0109），頁20-21（2020年）。

46 Comandè & Schneider, *supra* note 43, at 566.

47 *Id.* at 567.

不同規範⁴⁸，因此對於以公共利益作為衡平個人資料權利，而合理舒緩對資料控制人與利用人之責任與限制言，其實未必友善。

不過，臺灣需要參考的資料再利用規範就其本質言，其實未必需要計較不同模式的嚴格或是鬆散，甚至是否全盤移植或棄守某個模式⁴⁹，重點毋寧為是否適合臺灣現在的法制需求。

(二) 歐盟GDPR⁵⁰與科研發展

不惟本文一開始所提到的2024年BTC相關建議，其實在2023年8月底BTC亦曾建議政府應成立國家級健康資料研究中心，來完備健康資料治理和應用研發，特別是推動資料互通性和可用性。其中在BTC委員總體觀察與建議報告中，特別就生醫大數據／生成式AI關於資料治理之面向，指出應「建立前瞻與嚴謹的資料保護制度，

48 *Id.*

49 例如美國在加州通過CCPA之後，即有討論是否由聯邦對於資料保護法制予以適度「放鬆」後立法，甚至直接對GDPR採取「複製貼上」之立法，或是選擇超越FIPs包容性且分層次的隱私法律型態。詳細的討論，see Hartzog & Richards, *supra* note 37, at 1712-16.

50 由於在歐盟資料策略(European strategy for data)中，資料治理框架之概念內涵係界定為「以保護個人隱私及資料安全，確保資料利用之公正、透明與負責任」(粗體字為本文強調)，因此本文認為在概念上，應將原本的個資保護法制，包括GDPR、電子通訊領域指令(ePrivacy Directive, ePD)，以及歐盟執法指令(Law Enforcement Directive, LED)等一般性與個別領域之個資保護法制視為是資料治理法制的一環。再者，從GDPR的立法目的而言，其第1條第1項開宗明義曰：「為規範關於保護個人資料處理與資料自由流通，特制定本規則(This Regulation lays down rules relating to the protection of natural persons with regard to the processing of personal data and **rules relating to the free movement of personal data.**)」(粗體字為本文強調)，衡酌相關之前言(Recital)，大致可被理解為保護個人資料以及令資料自由流通均為GDPR之目的。從而，本文認為資料保護與資料治理兩個概念彼此關聯，並且隨著資料法制的發展，資料保護應被視為是資料治理法制框架中獨立的一環，而這個概念也可以從歐盟資料治理法(Data Governance Act, DGA)前言第4點「本規則應不影響已公告施行包括個人資料與非個人資料相關的規則或指令，例如GDPR」得證。基於此，本文在架構上於第貳部分「歐盟一般資料與健康資料之再利用法制」下第一節「不同的資料法制模式與科研發展」中，對GDPR與科研發展加以說明，而非指「資料治理」概念即等同於「個資保護」之概念，併此敘明。

保護個人醫療資訊隱私安全，同時鼓勵推動群體健康資訊應用於科研及商化」⁵¹。既然在策略上BTC期待政府能推動將健康資料應用於科學研究與商業關係中的前提是能建立「前瞻與嚴謹的資料保護制度」同時「鼓勵推動群體健康資訊應用於科研及商化」，那麼探求臺灣當前資料法制可能之模式，便顯得重要。就此，本文認為歐盟GDPR之資料保護法制模式，或許仍符合臺灣現在及未來的需求。

就GDPR第89條之基於科學學術或歷史研究目的而就特定目的外利用的衡平而言，在結構上，第89條第1項規範了為了實現公共利益而目的外利用個資為研究之保護措施⁵²，不過隨即在第89條第2項⁵³及第3項⁵⁴就歐盟法與會員國法做出例外「排除」(derogation)之寬鬆規定，允許會員國依照其本國法之法律體系或國情本身的實際情況，為一定之衡平調整規範。例如，德國個資法

51 2023行政院生技產業策略諮議委員會會議，委員總體觀察與建議，頁34，<https://www.nstc.gov.tw/nstc/attachments/33ae4cbd-a201-4723-8353-6c05359fc840>（最後瀏覽日：2023年8月31日）。

52 GDPR第89條第1項：「為實現公益建檔、科學或歷史研究目的或統計目的之處理，應受本規則為資料主體之權利及自由所定適當保護措施之拘束。該等保護措施應確保已備妥技術上及組織上之措施，特別是用以確保資料最少蒐集原則之落實。該等措施得包括假名化，只要得以此方式實現上述目的。倘得以無法識別或無法再識別資料主體之方式實現上述目的，則應以此方式實現上述目的。」參：個人資料保護委員會籌備處，GDPR第89條中文翻譯參考，<https://ws.pdpc.gov.tw/Download.ashx?u=L0ZTMDEvRmlsZVBhdGgvMy9yZWxmaWxlLzI0LzExL2Q4OTcyN2RhLTA3ZjktNGE4YS04NmViLTl4N2QwMWEzYjQ5Ny5wZGY%3D&n=R0RQUesrDg55qKd5Lit5paH57%2B76K2v5Y%2BD6ICDLnBkZg%3D%3D>（最後瀏覽日：2025年7月29日）。

53 GDPR第89條第2項：「為科學或歷史研究目的或統計目的處理個人資料者，歐盟法或會員國法在符合本條第一項所定要件及保護措施之前提下，得就第15條、第16條、第18條及第21條所定之權利訂定例外規定。但僅限於該等權利可能致使特定目的之達成無法實現或受嚴重損害，且例外規定對於該等目的之實現係有必要之範圍內。」參：個人資料保護委員會籌備處（註52）。

54 GDPR第89條第3項：「為公益建檔處理個人資料者，歐盟法或會員國法在符合本條第一項所定要件及保護措施之前提下，得就第15條、第16條、第18條、第19條、第20條及第21條所定之權利訂定例外規定。但僅限於該等權利可能致使特定目的之達成無法實現或受嚴重損害，且例外規定對於該等目的之實現係有必要之範圍內。」參：個人資料保護委員會籌備處（註52）。

(Bundesdatenschutzgesetz, BDSG⁵⁵)第27條便排除GDPR第9條第1項對於特種個人資料之限制，而令即使未有當事人之同意，若屬為達成科學研究目的所必要，並且於利益權衡後如果控管者處理個人資料所獲致之利益明顯地高過於當事人排除該處理所得之法益時，就可處理特種資料。再者，既然該等衡平情狀係例外之規範，因此解釋上理應採取較為嚴格之限縮解釋方法，令該等例外情狀範圍減縮。又，BDSG第27條第2項第1句更依GDPR第89條之授權，例外限制個資當事人相關權利⁵⁶。惟，此等基於衡平權利例外限制必須特別注意兩點：(1)該等例外情狀在會員國立法時，基於法條規範的結構，會員國國內法在規範時，必須考量該等衡平規範之立法乃需確實有助於達成第89條各項本身之目的⁵⁷；以及(2)同時亦要求應採行相關之配套措施⁵⁸，以維護當事人之自由與權利⁵⁹。

55 Bundesdatenschutzgesetz [BDSG] [Federal Data Protection Act], https://www.gesetze-im-internet.de/englisch_bdsg/englisch_bdsg.html (Ger.).

56 李寧修，個人資料合理利用模式之探析：以健康資料之學術研究為例，臺大法學論叢，49卷1期，頁32-33（2020年）。

57 Christian Wiese Svanberg, *Article 89 Safeguards and Derogations Relating to Processing for Archiving Purposes in the Public Interest, Scientific or Historical Research Purposes or Statistical Purposes*, in THE EU GENERAL DATA PROTECTION REGULATION (GDPR): A COMMENTARY 1240, 1246 (Christopher Kuner et al. eds., 2020).

58 部分會員國落實GDPR時，在其國內法即有對應之例外排除條款以及對於例外排除之限制，例如英國的Data Protection Act 2018在其Schedule 2的Sections 27-28, Part 6即有規範。另外，BDSG第27條第3項針對基於研究或統計目的處理特種個人資料之情形，除要求應採行BDSG第22條第2項對於處理特種個人資料所定適當且特定措施外，在處理特殊類別的個人資料時，必須儘可能保持匿名，直到這些資料可以被安全地匿名處理或與其他資料結合並且不會對個資主體造成任何損害或損失為止。如果資料處理人需要將這些資料與其他資料結合，則其必須確保需僅在必要的範圍內進行。

又，BDSG第22條第2項所指的「配套措施」，包括增加員工參與操作的意識、指定一名資料保護官、限制個資控管者和個資處理人對個人資料的近用、對個人資料進行假名化和加密、確保系統和服務的可用性、機密性、完整性、可操作性及安全韌性，並建立測試、評估和評估技術和組織措施的有效性之過程，以及需要制定具體的程序規則，以確保在轉移或其他目的之處理時，能遵守BDSG和GDPR。

59 Jos Dumortier & Mahault Piéchaud Boura, *European-wide Big Health Data Analytics*

不過在此等雖有豁免，卻必須嚴格解釋的情況下，為什麼本文還是認為GDPR可能符合臺灣追求健康資料加值應用之政策呢？本文認為這是因為GDPR在例外允准利用的適用範圍上與CPRA之規定相異，其判斷標準乃是所涉研究實體之本質。

細究之，如果在體系上將GDPR第89條第2項及第3項二者合併觀察，可發現「公共利益」之考量僅出現在第89條第3項關於建檔（“personal data are processed for archiving purposes in the public interest”）之段落，而並未相對地呈現於關於科學或歷史研究或統計目的的第89條第2項（“personal data are processed for scientific or historical research purposes or statistical purposes”）的規範文字當中，因此解釋上即便沒有「其他」公共利益的出現，科學研究等目的仍可為會員國法作為前揭排除規定之理由。然則，難道此處之法益衡平可以不需要考量任何的公共利益嗎？本文不認為如此。相反地，GDPR乃是將享有科學或歷史研究以及統計等行為之成果的利益，預設為一種公共利益，而建立檔案本身只是為其他某種目的之手段方法，因此需要另外有一個支撐的基礎公共利益，作為與個資權利衡平之依據。換言之，此處的科學研究乃是在本質上即被保障之權利⁶⁰，以及使個人得享有科學進步及其應用成果利益之權利⁶¹，而與前述CCPA/CPRA之判斷標準不同。又，此處關於科研之目的，依照GDPR前言第159點，亦應從寬解釋而使之範圍擴大，如對比CCPA/CPRA以觀，科學研究在範圍與本質上，歐盟資料模式都相對有利。

再者，由於現行的GDPR當中對於科研為例外的特定目的外個資利用，判斷標準採取的是對於科研本質之認定，加上GDPR前言

under the GDPR, in HEALTH DATA PRIVACY UNDER THE GDPR: BIG DATA CHALLENGES AND REGULATORY RESPONSES 56, 66 (Maria Tzanou ed., 2021).

⁶⁰ 歐盟基本權利憲章第13條參照。

⁶¹ 經濟社會文化權利國際公約第15條參照。

第159點明文指出GDPR對於為科學發展及應用成果，以及「私人贊助之研究」(privately funded research)均應採較寬鬆之擴張解釋，因此有私人企業參與而涉及商業研究的潛在創新研究類型，受到之阻礙即相對較加州的資料法制可能來得小。

綜合以上所述，針對個人資料在促進科學研究方面的保護法制，可以發現其實歐盟資料法制模式並不見得必定不利於研究發展⁶²。然需注意者，歐盟的GDPR在解釋上對於利用個人資料進行科學研究採取了較寬鬆之解釋，並在限制上採取了較緩和的方式，為成員國立法提供了更大的評斷餘地(margin of appreciation)。然而，吾人也不應該錯誤地認為GDPR過度偏向於促進科學研究成果的享受。

綜上，雖然從傳統形式關於資訊隱私權以及科學研究所帶來公共利益二者的角力與制度價值來看，美國資料法制模式以及歐盟資料法制模式之預設與偏重本有不同，然則因為：

- (1)既然美國部分資料法制(例如CCPA/CPRA)逐漸傾向於對接對於國際影響力較深的歐盟資料法制模式；
- (2)如同本文前揭討論，看起來對科學研究嚴格的歐盟資料法制模式在實質內容、解釋方向以及最新的資料治理法制發展上，對於科學研究面相的資料再利用與共享，都(逐漸)趨向友善；
- (3)在美國資料法制與歐盟資料法制的發展中，在實務上與論理⁶³層面都指出建立信任關係為核心價值。

62 事實上對於商業活動來說，亦有論者持相同見解參：Kenneth N. Rashbaum, *The Business Opportunities of GDPR*, in *THE GDPR CHALLENGE: PRIVACY, TECHNOLOGY, AND COMPLIANCE IN AN AGE OF ACCELERATING CHANGE* 125, 125-43 (Amie Taal ed., 2022).

63 美國的學術論理中，以Jack M. Balkin教授為首的觀點，在關於資料共享的資訊受託人模式當中，亦將信任關係視為核心之所在。Jack M. Balkin, *Information*

因此，本文認為或許未來無論採行何等資料模式，都有可能因為在不斷地利益權衡之間而漸趨實質融合，而使得「放棄歐盟資料法制模式」成為一個實質意涵弱化的議題。由於本文在此除分析歐盟資料法制具備「前瞻與嚴謹的資料保護制度」外，重點亦在探索其是否兼備「鼓勵推動群體健康資訊應用於科研及商化」之特質，故以下將說明著重關於個資之（再）利用部分。

二、歐盟資料治理法制模式：對健康科學研究的複雜資料治理框架

即便有前節之分析，歐盟的整體資料法制仍舊難以擺脫複雜體系之問題。然則，本文認為之所以出現複雜的資料法制框架規範，除了歐盟之一般法制本身因為需與會員國本身法體系為一定程度銜接，以及歐盟本身法律系統就相對複雜以外，資料法制愈顯複雜之原因，或許也在於由於近年資料應用的發展快速，因此資料法制需要保持更即時的動態化。在動態化的過程當中，在歷經原先將焦點放在個資權利保護長達廿餘年後，歐盟資料法制於2020年歐盟採行資料策略（European strategy for data）之政策起，則展開新頁，將注意力兼及於資料之利用，以更強化個資當事人之控制權。

（一）歐盟資料法制之架構：從一般資料治理到健康資料治理

歐盟資料策略的主要目標是促進歐洲資料的開放、共享與再利用，提升歐洲的數位轉型能力。其重點內容包括：(1)創建歐洲資料空間：藉由整合歐洲的資料資源，建立資料共享的基礎設施，促進跨境資料流通與再利用；(2)支持歐洲中小企業：透過資料的共享與再利用，提升尤其是歐洲中小企業的創新能力，促進歐洲產業的發

Fiduciaries and the First Amendment, 49 U.C. DAVIS L. REV. 1183, 1161 (2016); Jack M. Balkin, *The Fiduciary Model of Privacy*, 134 HARV. L. REV. F. 11, 29 (2020) (Responding to Lina M. Khan & David E. Pozen, *A Skeptical View of Information Fiduciaries*, 133 HARV. L. REV. 497 (2019)).

展；(3)加強資料治理：建立更加健全的資料治理框架，保護個人隱私及資料安全，確保資料的公正、透明與負責任的使用；(4)促進公共部門資料開放：推動歐洲各國政府開放其公部門資料，以提高公共部門效率及服務品質；以及(5)增加資料人才培育：提升歐洲的資料科學與人工智慧人才培育等⁶⁴。在這樣的政策架構下，公部門資料之流通（再）利用、支持中小企業的資料等目的即生共享歐盟資料治理的規範需求，歐盟也因此通過資料治理法（Data Governance Act, DGA）⁶⁵，並於2023年8月生效。此外，在技術上也出現能夠「遵循資料工程方法，優化資料存儲和交換機制，保留、生成和分享新知識」⁶⁶的資料空間需求，亦即一個進行資料共享之平台——資料空間（data spaces）⁶⁷。

在歐盟法制框架上與因此出現對於資料空間之規範需求，其原因主要在於雖然GDPR已經是歐盟規則（Regulation）之層級，但是由於其仍保留部分會員國法體系豁免之空間，因此在不同會員國對GDPR的不同解釋和轉換實施，以及對GDPR的不清晰理解，形成法律的不確定性，也因此被視為在歐洲跨境個人資料交換與流通的障礙。為弭平該等障礙，歐盟便匯聚了相關的資料基礎設施和法制

⁶⁴ *Communication from the Commission to the European Parliament, the Council, the European Economic and Social Committee and the Committee of the Regions: A European strategy for data*, COM (2020) 66 final (Feb. 19, 2020) [hereinafter A European strategy for data].

⁶⁵ Regulation (EU) 2022/868 of the European Parliament and of the Council of 30 May 2022 on European data governance and amending Regulation (EU) 2018/1724 (Data Governance Act) (Text with EEA relevance), 2022 O.J. (L 152) 1, 1-4 [hereinafter DGA].

⁶⁶ Edward Curry et al., *Data Spaces: Design, Deployment, and Future Directions*, in DATA SPACES: DESIGN, DEPLOYMENT AND FUTURE DIRECTIONS 1, 3 (Edward Curry et al. eds., 2022).

⁶⁷ 關於資料空間之定義，學說上認為係一個集合名詞，而可能有多種意涵，不過共同的交集仍約略在於一個具信任框架的資料共享平台。學說上對於資料空間定義之整理，可參：Id. at 4.

治理框架⁶⁸，以架構通常性質的共通資料空間（European Common Data Space）。其主要的特點包括：(1)安全且注重隱私的基礎設施，用於聚合（pool）、近用、共享、處理和利用資料；(2)採用公平、透明、比例適當和非歧視性方式近用和利用資料的清晰實用結構，以及明確可信的資料治理機制；(3)不影響而完全遵守歐盟法制和價值觀，尤其是個人資料保護（尤其是GDPR）、消費者保護法和競爭法等；(4)資料持有者將有可能在資料空間中，授予對其控制下的某些個人或非個人資料的近用或共享權；(5)提供的資料可以有償或無償方式再利用；以及(6)開放數量不受限制之組織或個人參與等⁶⁹。

在共通資料空間乃針對一般性之資料空間予以規範外，歐盟執委會也規劃建立9個較常應用的個別領域歐洲資料空間，例如歐洲移動（交通）資料空間、歐洲健康資料空間、歐洲金融資料空間、歐洲公共行政資料空間，以及歐洲技能（教育與勞動整合）資料空間等⁷⁰，對於不同領域之群體資訊隱私權利，予以不同之調和規範。

其中與本文有直接關係者，自為歐盟執委會於2022年所提出的「歐洲健康資料空間規則提案」⁷¹。其立法之背景脈絡，除了因為COVID-19大流行令歐盟認知電子健康資料對於擬定突發衛生緊急事件對策的重要性，在法規上急需對應確保即時近用個人電子健康資料以應對健康威脅之必要性以及其他健康資料應用領域外⁷²，更聚焦在弭平GDPR在各會員國間對於健康資料應用規定之落差。細

⁶⁸ Commission Staff Working Document on Common European Data Spaces, at 2, SWD (2022) 45 final (Feb. 23, 2022).

⁶⁹ *Id.* at 2-3.

⁷⁰ See A European strategy for data, *supra* note 64.

⁷¹ See European Health Data Space proposal.

⁷² European Health Data Space proposal recitals 1-4; European Health Data Space recitals 2-3.

言之，在GDPR中對於擁有共同健康生物特徵之群體，以包括基因資料、生物特徵資料以及健康資料之概念，規範於特種資料中：這些個人資料所包含者並不僅止於該特定個人純粹之個資，亦包含了整個親族或特定家庭成員，因此GDPR當中對於該等特種個資調整為原則上不得加以處理⁷³。就此而言，GDPR雖然在性質上屬於「一般性」(general)之基本法模式的資料保護規範⁷⁴，然就各種可能的特殊情境類型已然予以分類。再者，在關於科學研究與個人資料權利衡平的GDPR第89條中也強調除了需要考量當事人之個資權利外，也需要與歐盟法或會員國法所定要件及保護措施前提加以考量（亦即需要有合法之基礎），因此如果透過在歐盟法或會員國國內法層級的法體系中安置，也是種可能的保護方式⁷⁵。不過即便如此，GDPR本身並沒有對於個別的特殊資料應用領域予以規範：在歐盟層級採取通常事務與特別事務聯立的個資保護體系⁷⁶，並給予會員國依照自身國情與法律體系情況調整的彈性授權。因此如果僅僅只存有GDPR本身，或如我國目前的資料法制狀態一樣僅只有一部基本法性質⁷⁷的個資法，就會形成不但無法完整規範各領域、各情境對個人資料蒐集、處理與利用及資料庫建置等不同情形⁷⁸，更無法顧及公共利益之保護與衡平問題。

73 GDPR的「處理」，實包括我國個資法上的「蒐集、處理與利用」三個行為。

74 劉定基，試評「數位通訊傳播法」草案，收於：彭芸、葉志良編，匯流、治理、通傳會論文集，頁286（2018年）。

75 Mark Taylor & Tess Whitton, *Health Research and Privacy through the Lens of Public Interest: A Monocle for the Myopic?*, in THE CAMBRIDGE HANDBOOK OF HEALTH RESEARCH REGULATION 239, 243-45 (Graeme Laurie et al. eds., 2021).

76 翁逸泓，數位通訊傳播管制與個資保護：APPLE與FACEBOOK的歐洲隱私權戰役啟發，東吳法律學報，33卷4期，頁42-48（2022年）。

77 在健保資料庫案中，將其稱為「框架性規範」。參：憲法法庭111年憲判字第13號判決段66。另外，我國個資法目前主責解釋機關國家發展委員會，則在健保資料庫案中，將個資法定性為普通法性質，而係個人資料保護之一般性規定。參：國家發展委員會（110）發法字第1102000017號函，司法院大法官為審理會台字第13769號蔡季勳等人聲請解釋案回應說明，頁3-5（以下簡稱：國發會（110）發法字第1102000017號函）。

78 國發會（110）發法字第1102000017號函（註77），頁3-5。

在前揭背景下，EHDS不意外地成為最迅速形成提案的規範，其整體目標乃是強化個人對電子健康資料的控制，以利各領域相關應用者能夠取得近用相關的電子健康資料，以促進更佳的診斷、治療和個人福祉，並循證以制定更佳政策，並藉由這個衡平權利之規則，為數位健康產品和服務建立單一市場，從而提高醫療保健系統的效率⁷⁹。此外，EHDS亦兼有追求包括促進不同類型電子健康資料之交換與近用，包括電子健康紀錄（electronic health records）、基因資訊（genomics data）、病患住院資料（patient registries）等。最後，對應DGA，EHDS亦包括建立公共衛生部門之資料利他（data altruism）⁸⁰機制。

綜上，在整體歐盟的資料法制架構上，乃具有從一般性資料保護／利用至個別領域，以及個資保護與促進資料再利用與共享聯立之體系。細言之，在為電子健康資料的再利用提供法制框架時，EHDS係以資料治理法（DGA）和資料法（Data Act⁸¹）為基礎。其中，作為調和會員國間法制之框架，DGA僅規定了公部門資料再利用的一般性條件，而未創造資料再利用的真正權利。又，資料法（提案）則增強了使用者個人所生成資料（包括健康資料）的可攜性，然而並沒有為所有健康資料提供適用之規則⁸²，因此EHDS補足前述法規之不足（關於健康資料之保護與治理規範規框架，參見表1）。

79 See European Health Data Space proposal.

80 依據DGA之定義，資料利他是指資料當事人或資料持有者自願共享資料而不尋求報酬，以實現依據適用的會員國國家法律定義的公共利益目標，例如科學研究目的、政策制定或改善公共服務等。See DGA art. 2(16). 中文文獻可參：翁逸泓，資料治理法制：歐盟模式之啟發，東海大學法學研究，64期，頁100-108（2022年）。

81 Regulation (EU) 2023/2854 of the European Parliament and of the Council of 13 December 2023 on harmonised rules on fair access to and use of data and amending Regulation (EU) 2017/2394 and Directive (EU) 2020/1828 (Data Act) (Text with EEA relevance), 2023 O.J. (L 2023/2854). 歐盟資料法於2024年1月11日生效，2025年9月開始適用。

82 European Health Data Space proposal, Explanatory Memorandum.

表1 歐盟電子健康資料之保護與利用／治理規範規框架

	一般領域	個別領域（健康資料）
資料保護	GDPR	N/A
資料利用／治理	DGA：僅規定了公部門資料再利用的一般性條件，並未創造資料再利用之真正權利。	EHDS：以DGA及Data Act為基礎，不影響GDPR，而為所有健康資料應用型態提供較細部適用之規則。 *EHDS亦與包括歐盟醫材規則（Medical Devices Regulation）、高度共通程度資安措施指令（NIS2）、網路韌性規則提案（Cyber Resilience Act），以及歐洲數位身分規則提案（European Digital Identity Regulation）相關聯。
	Data Act：增強了使用者所生成資料的可攜性，包括健康資料；然並未為所有健康資料提供規則。	
	Artificial Intelligence Act (AIA) ⁸³ ：若醫療設備和高風險AI系統製造商宣稱其與電子健康資料系統具有互通性，則亦需要遵守EHDS對互通性之基本要求。	

資料來源：本表整理自歐盟健康資料空間規則提案解釋備忘錄，European Health Data Space proposal, Explanatory Memorandum。

83 Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 laying down harmonised rules on artificial intelligence and amending Regulations (EC) No 300/2008, (EU) No 167/2013, (EU) No 168/2013, (EU) 2018/858, (EU) 2018/1139 and (EU) 2019/2144 and Directives 2014/90/EU, (EU) 2016/797 and (EU) 2020/1828 (Artificial Intelligence Act) (Text with EEA relevance), 2024 O.J. (L 2024/1689).

(二) 歐盟資料法制將資料當事人對健康研究的參與，理解為與研究者基於信任關係的研究夥伴

GDPR本身的立法目的依其第1條所指，除了保護個人資料之處理以外，也在於資料的自由流通，並兼顧衡平該二目的與其他所有的個人基本權利與自由。承前揭分析，既然本文討論主題為在特定目的外利用個人健康資料於科學研究，那麼在分析管制框架的衡平問題上，第一件要處理的乃是辨識出到底要衡平的，也就是可能隱含衝突的究竟是哪些基本權利或自由。本文認為該等基本權利或自由，包括了公共利益以及個人利益⁸⁴，至少可能涉及了個人資料權利、享受科研進步成果利益之權利，以及潛藏的產業應用後的財產／經濟權利等。

論者認為此際應當將研究者當作是與研究參與者（例如受試者、個資當事人等）共同就科學研究發展的轉譯夥伴（interpretative partner）；同時，研究者在尋求實現研究本身的公共價值的同時，就其自身之資料當事人責任也需要取得平衡⁸⁵。細言之，過去自生醫倫理面向上，已有提出個人有倫理上義務以參與研究（duty to participate）者⁸⁶，而這個理論甚至實際地應用在英國的「10萬基因體計畫」（100,000 Genomes Project）之中。然則必須特別予以辨明者，這個論理的實踐基礎重點毋寧在於對研究者與參與者之間基於夥伴關係的信任建立⁸⁷，而並非是單方面地要求研究參與者的義務，並且服從於研究者的權威之下。具體而言，即便基於「團結」

84 Graeme Laurie, *Private and Public Dimensions of Health Research Regulation: Introduction*, in THE CAMBRIDGE HANDBOOK OF HEALTH RESEARCH REGULATION 227, 227-28 (Graeme Laurie et al. eds., 2021).

85 Emily Postan, *Changing Identities in Disclosure of Research Findings*, in THE CAMBRIDGE HANDBOOK OF HEALTH RESEARCH REGULATION 229, 236-38 (Graeme Laurie et al. eds., 2021).

86 See John Harris, *Scientific Research Is a Moral Duty*, 31 J. MED. ETHICS 242, 242-48 (2005).

87 Postan, *supra* note 85, at 234-35.

(solidarity) 而令參與者有義務將健康個資提供參與研究，然則，過度地傾斜於團結的條件要求之下便升高了對於個人權利侵害之風險，尤其是如果採行上對下 (top-down) 模式的團結要求，那麼「願意為他人承擔成本」之假設如果沒有良好的治理制度與實踐⁸⁸，則不但是前揭風險更高，且團結之維持可能無以為繼。此間，信任關係之建立與擔保即成為維持團結的關鍵因素。

準此，本文認為既然要將二者以夥伴關係對待，且信任關係的建立極其重要，那麼由於相對於研究參與者（資料當事人）來說，研究者對於研究本身的操控能力與可能性明顯較大，因此需要擔負的資料控制人責任也應當更重。正是基於此種考量，本文認為歐盟資料模式這種對於資料控制人要求負擔較高強度責任之管制模式，能考量權力不對等關係，以充分地衡平彼此的利益⁸⁹。

由於前揭的論理以及各要件之具體化，例如對於健康資料再利用者（研究者）與參與者之間信任關係之建立，以及資訊託管人責任之強化與監督等，除在歐盟資料治理法（DGA）中可以尋得外⁹⁰，EHDS亦有關於健康資料再利用之治理機制完整規範⁹¹。

綜上，至少在制度的規範上，歐盟資料法制已然開始將資料當事人對健康研究的參與，設計為與研究者基於信任關係的研究夥伴。雖如此，歐盟此複雜的資料法制規範體系，如何實踐落實於國家之法制，而實踐的過程中又可能會遭遇何種難題，則需要進一步

88 CAROLYN ADAMS ET AL., SHARING LINKED DATA FOR HEALTH RESEARCH: TOWARDS BETTER DECISION MAKING 52-54 (2022).

89 這個論理的觀念延伸於後階段研究成果之資料分享，則與「資料受託人模式」相通。關於資料受託人模式之中文文獻可參：劉靜怡，人工智慧時代的法學研究路徑初探，收於：李建良編，法律思維與制度的智慧轉型，頁122-124（2020年）；翁逸泓（註80），頁88-99。

90 See DGA art. 12. 關於DGA當中資訊託管人責任之介紹與分析，參：翁逸泓（註80），頁96-99。

91 European Health Data Space Chapter IV: Secondary use.

地分析。就此，本文將以同樣因為有全民健保制度、同樣實踐歐盟資料法制模式的英國相關健康資料再利用案例，作為分析起點。

參、英國的失敗經驗、教訓以及新方向

一、英國的資料法制與健康資料加值應用經驗：信任的形塑

於資訊隱私以及個人資料權利受重視以來，英國關於享受科學研究成果之利益與隱私權利之實例並不缺乏：英國的 *Source Informatics* 案⁹²即是關於個人健康資料與科學研究的指標判決⁹³。由於健康資料的高敏感性特徵，因此幾乎所有的健康資料在普通法中均有保密之義務，從而在多數情況下其實分享或再利用健康資料都會基於保密義務而有一定程度的「去識別化」作為。正因如此，在1999年的 *Source Informatics* 案中，法院以普通法之角度認定即便為資料特定目的外之利用，只要分享予第三方時已經有一定程度的「匿名化」，即不違反保密義務。然則，這個顯然忽略該等程度的「匿名化」仍可能有涉資訊自主與對於個資當事人資料權利所生影響的判決⁹⁴，毫無意外地引起相當大的爭論，而被學者認為這個判決對於歐洲人權公約第8條家庭與私生活權利做出了過度限縮的解釋⁹⁵。

需特別注意者，由於本案是在歐盟個資保護指令（Directive 95/46/EC）落實轉換於英國的1998年資料保護法（Data Protection

92 R v. Department of Health, ex p. Source Informatics [1999] 4 All ER 185; R v. Department of Health, ex p. Source Informatics [2000] 1 All ER 786.

93 Mark Taylor, R v Department of Health, ex parte Source Informatics Ltd [1999], in LANDMARK CASES IN MEDICAL LAW 175, 175-92 (Jonathan Herring & Jesse Wall eds., 2015).

94 *Id.* at 185-91.

95 Deryck Beyleveld, *Conceptualising Privacy in Relation to Medical Research Values*, in FIRST DO NO HARM: LAW, ETHICS AND HEALTHCARE 151, 152 (Sheila A. M. McLean ed., 2006).

Act 1998) 之前⁹⁶所為之判決，因此判決的依據僅有普通法上的保密義務問題，而與歐盟的個資保護規範體系無涉，所以對於該等去識別化的個人資料在資料法制上，並未有所評價。不過，在歐盟資料保護模式於英國落實之後，便開始出現政府將個人健康資料再利用的政策與挫折的經驗，此乃後話。

(一) 第一次失敗與檢討：care.data計畫

英國的國民健康服務(National Health Service, NHS)主要依賴向民眾徵收的一般性稅收(general taxation)作為財源收入。所以若能更有效地整合健康資料，無論是節省資源(避免資源應用效率低下或濫用)或開放資源(將健康資料予以再利用，甚至發展商業模式)，都對財務營運有所幫助。因此，早在2011年左右，英國政府開始制定對健康資料再利用的政策。其中，care.data計畫是NHS於2012年推出的第一個計畫，原本的目的是透過從患者醫療紀錄中蒐集資料，以更好地理解 and 改進國家的公共醫療服務。然而，由於隱私和安全等問題的爭議，該計畫以失敗告終。其之所以在2016年草草收場，主要的困境大致上落在規範以及執行上的雙重問題：於規劃設計時對於個人資料與隱私權利的規範欠缺明確性與法律保留，因此care.data計畫本身本來就可能會導致患者的個人敏感資料被洩漏或濫用之疑慮；更為關鍵之處在於當時實際的執行過程中，即便是號稱有妥善地利用信件與大眾「說明溝通」，但是民眾事後發現該等所謂的溝通僅是單向的政策宣導，而相關紙本傳單大多數跟氾濫的連鎖Pizza店廣告訂購單一樣進了垃圾郵件堆當中⁹⁷，而負責第一線執行的家庭醫師，更是消極抵制⁹⁸。其後國家健康與照護

96 英國1998年資料保護法至2000年3月方生效，Source Informatics案則於1999年12月判決。

97 Nick Trigg, *Care.data: How Did It Go So Wrong?*, BBC NEWS (Feb. 19, 2014), <https://www.bbc.com/news/health-26259101>.

98 翁逸泓(註16)，頁164-167。

保障委員（National Data Guardian for Health and Care, NDG）即在關係報告中強調了使用健康資料進行研究和分析的潛在好處，同時強調了需要確保透明、安全，並尊重患者隱私的重要性⁹⁹。該份報告的20點建議，約略之重點綜整如下：

- (1)強化資料安全：報告強調資料安全是保護資料當事人（病人）隱私的最基本要求。為了確保資料安全，報告建議NHS必須制定一套統一的安全標準，並對所有資料利用者都實施嚴格的安全管理和監控。
- (2)統一的資料管理：報告建議NHS需要建立一個統一的資料管理框架，確保所有資料利用者在程序上都遵守同樣的資料管理和安全標準。
- (3)確保病人之知情同意與退出權等權利：報告強調資料當事人（病人）必須知道自己的資料如何被利用，並且對其使用為明確的同意。報告還強調了病人退出資料共享行為的權利，並建議NHS制定一套統一的退出程序，確保病人可以方便地退出資料共享計畫。

除了在該報告的破題第一句話「這是一份關於信任的報告」（“This is a report about trust”），就開宗明義地揭示整個失敗經驗的癥結在於政府與民眾間的信任問題以外，這份檢討為何政府對於健康資料再利用這等福國利民政策卻以慘敗作收的報告，在最後更是語重心長地建議應該在國家資訊委員會（National Information Board¹⁰⁰）

99 National Data Guardian, *National Data Guardian for Health and Care: Review of Data Security, Consent and Opt-Outs* (June, 2016), https://assets.publishing.service.gov.uk/government/uploads/system/uploads/attachment_data/file/535024/data-security-review.PDF.

100 National Information Board (NIB) 是英國政府於2014年成立的一個部門，旨在協調和推動英國全國醫療和社會照護領域的數位化轉型。NIB的主要目標是確保各種數位技術在醫療和照護領域得到廣泛應用，以提高醫療和照護的效率、品質和安全性。需注意者，英國NIB和Health and Social Care Information Centre (HSCIC) 是兩個不同的機構，它們的任務和職責也有所不同：前者是

持續研究該諮詢報告所提出的結論，以及如何建立更好的公眾信任，促進醫療和社會照護領域的資料分享。

(二) 第二次的挫折：GPDPR

然而，很不幸地這個至關要緊的「建立公眾信任」政策建議，似乎並未真正地在隨後的幾年間看到落實的成效：十年後，NHS於2021年的健康資料再利用共享計畫：the General Practice Data for Planning and Research (GPDPR)¹⁰¹中，又再度地因為人民對於政府對高敏感健康資料利用的信任關係有所懷疑的緣故，暫時擱置¹⁰²。

然則，這倒也不是說英國政府完全未汲取care.data計畫失敗的教訓。例如從退出權的角度來看，英國從2013年開始有第一類型退出 (Type 1 opt-out) 以及第二類型退出 (Type 2 opt-out)，讓民眾可以註冊選擇不共享其個人健康資料：前者之退出乃是限制除了家庭醫師基於照護病人目的外，不得再與他人資料分享；後者則是將健康資料由家庭醫師上傳到NHS後，除個人直接照護目的外，不再為目的外分享個人健康資料。其後在2018年5月25日歐盟GDPR施行日的同一天起，前揭第二類型退出轉型為國家資料退出 (national data opt-out)。再者，基於前揭care.data計畫以紙本書面為唯一溝通方式的失敗教訓，在新的國家資料退出模式中，民眾可以用紙本、電話、線上以及APP等科技態樣，選擇退出個人健康資料

一個由英國政府成立的委員會，主要職責是協調各方的合作，制定政策和策略，以推動英國醫療和社會照護領域的數位化轉型；而後者則是NHS內的一個機構，負責蒐集、處理和共享醫療和社會照護領域的資料，確保資料的安全和隱私，以支撐醫療和社會照護服務的提供和管理。NIB在2019年改制為NHSX，HSCIC在2016年改為NHS Digital，而這些機構至目前為止均於2023年2月整併於NHS England。

¹⁰¹ GPDPR計畫參考：General Practice Data for Planning and Research (GPDPR), NHS ENGLAND, <https://digital.nhs.uk/data-and-information/data-collections-and-data-sets/data-collections/general-practice-data-for-planning-and-research> (last visited Aug. 1, 2025).

¹⁰² 何之行 (註16)，頁11-12。

的不同利用方式¹⁰³，包括選擇退出自己的醫療和健康資料被用於政府的醫療健康規劃和管理等公共服務，以及被用於研究和發展新治療方法¹⁰⁴。總而言之，GDPR計畫的退出機制包括：任何時候都可以多樣方式退出，退出後個人資料將不再被蒐集和共享；建立更嚴格的安全措施和監管機制，以確保個人資料的安全和隱私。此間，由於第一類型退出只適用於醫療照護資料的利用，而GDPR涉及健康和社會照護資料的利用，因此其並不適用於GDPR計畫。

不過即便有了以上多樣選擇退出類型與方式，GDPR計畫還是因為再度地出現了民眾對於資訊隱私和安全性的擔憂，以及對於資料利用透明度和可控性的質疑，而遭遇挫敗：在2021年5月悄然宣布的GDPR計畫原本所給予民眾的退出期只有短短的6週，但因為遭遇到醫師領袖的反對而延展到同年9月，只不過由於醫療保健機構、患者權益組織，以及隱私倡議團體在整個夏天都在網路世界積極地宣傳鼓動人們選擇退出，再加上媒體報導以及社群媒體的推波助瀾¹⁰⁵，因此在5月間有大約10萬餘人選擇退出，到了6月居然增加到127萬人（佔全體之2.08%）選擇退出，到了7月1日共計有303萬人（佔全體之4.97%）退出¹⁰⁶，因此在當年8月即凍結計畫。

¹⁰³ *Setting or Changing a National Data Opt-out Choice*, NHS ENGLAND, <https://digital.nhs.uk/services/national-data-opt-out/understanding-the-national-data-opt-out/setting-or-changing-a-national-data-opt-out-choice> (last visited Mar. 24, 2023).

¹⁰⁴ 關於國家資料退出模式之詳細內容，包括選擇方法、適用範圍與例外情況等，參*Understanding the National Data Opt-out*, NHS ENGLAND, <https://digital.nhs.uk/services/national-data-opt-out/understanding-the-national-data-opt-out> (last visited Mar. 24, 2023).

¹⁰⁵ Chaminda Jayanetti, *NHS Data Grab on Hold as Millions Opt Out*, THE GUARDIAN (Aug. 22, 2021), <https://www.theguardian.com/society/2021/aug/22/nhs-data-grab-on-hold-as-millions-opt-out>.

¹⁰⁶ [MI] *National Data Opt-out, July 2021*, NHS ENGLAND (July 22, 2021), <https://digital.nhs.uk/data-and-information/publications/statistical/national-data-opt-out/july-2021>.

那麼，究竟又是哪裡出了問題？究其所以，相關倡議團體對於GDPR計畫疑慮的主要訴求有二：

1. 資訊隱私和安全性

在這方面主要的疑慮焦點在於倡議團體與民眾擔憂計畫中的個人醫療與健康資料可能會遭到濫用或不當處理，導致敏感資料外洩或被盜取。再者，即使資料經過去識別化，仍然存在被重新再識別的風險，因此仍可能會損害公民的隱私權。最後，對於資料之利用因為可能存有歧視之問題，例如可能對少數族裔、社會經濟地位低下的人群造成不公平的影響，而這個可能造成歧視的問題，或許正導致居民在社經地位上較為弱勢的地區，退出之比率顯著較高¹⁰⁷。

2. 資料利用透明度和可控性

在此面向上癥結點在於除了分享個人健康資料予科學研究之外，由於GDPR也預計將其應用在商業化行為，因此使得民眾擔心無法知悉以及控制其個資之再利用行為，相關團體也認為公民應該有更大的控制權，以決定自己的資料是否可以用於商業目的。再者，政府在GDPR剛開始宣布的時候或許是擔心退出人數過多，又或是在計畫進行中如果民眾退出可能對已經處理過之資料造成成本上或技術上之刪除困難，因此一開始時的退出規則是過了退出期後，民眾即不可再為退出，直到後來遭到抗議，方修正為任何時間點均可退出。

（三）可信任的研究環境

綜合前述相關經驗的爭議所在，無論是關於再識別風險、將健康資料分享予第三方為商業利用、歧視、以及退出權之完整之間

¹⁰⁷ 關於GDPR社經地位居民區域與退出率之扼要說明，參：何之行（註16），頁20-21。

題，事實上都與基於健康資料之研究者（即資料利用人）與資料當事人相互間之信任關係相牽連。幾乎毫無意外地，約莫在凍結GDPR計畫當時的前後，由於受到了一片來自人民不信任的挑戰，英國政府乃將健康資料的資料分享關係的關懷焦點轉向以「可信任的研究環境」（*trusted research environment*, TRE）為中心的資料共享模式，英國政府也宣稱未來如果要重啟該計畫，則一定會是在TRE的條件之下，始將近用個人健康資料。

不過時序上其實英國衛生暨社會照顧部（*Department of Health and Social Care*, DHSC）早在2022年委託牛津大學應用科學研究所的臨床專家Ben Goldacre教授主持正式出版「更好、更廣、更安全：利用健康資料於研究與分析」（*Better, Broader, Safer: Using Health Data for Research and Analysis*¹⁰⁸，以下簡稱：Goldacre Review），而正好Goldacre Review是在GDPR計畫發生隱私與醫療倡議團體提出訴求後方總結提出，故DHSC便將TRE視為其有關NHS健康資料共享的建議核心，使得Goldacre Review成為英國健康資料再利用與共享政策的核心文獻，並且直接出現在相關政策當中¹⁰⁹。在Goldacre Review中，所謂的TRE在技術上指的是一個受到控制的安全環境，研究人員進入該環境方可遠端處理資料，而不是將其下載到自己的設備，因此不能從TRE中刪除單層級之資料，但在資料控制人批准後，可以匯出例如彙總後的分析結果¹¹⁰。換句話說，健康資料庫的使用者可以從分析中取得和下載所提出問題的答案，幫助分析師有效地處理資料，但是個別患者的資料始終保持在

108 Ben Goldacre & Jessica Morley, *Better, Broader, Safer: Using Health Data for Research and Analysis*, DEPARTMENT OF HEALTH AND SOCIAL CARE (Apr. 7, 2022), <https://www.gov.uk/government/publications/better-broader-safer-using-health-data-for-research-and-analysis>.

109 詳見本文參、二部分。

110 Goldacre & Morley, *supra* note 108, at 104-06.

安全環境中以防止和檢測資料的濫用，並提供個資當事人相關操作的完全開放和詳細的公共日誌紀錄¹¹¹。

為了解決過去極大化機器自動近用個人健康資料以及病人隱私無法兼顧的問題¹¹²，在隱私保護層面之重點在於藉由「可證明的、可信的方法來保護患者隱私，並向所有人透明地闡述其對患者最深層醫學機密所採取的所有措施」¹¹³，以將TRE描述為實現建立信任的明確途徑。TRE事實上也正被廣泛應用於英國的健康資料計畫，包括Health Data Research UK (HDR UK)、Our Future Health和Genomics England等¹¹⁴，甚至在GDPR被遭到凍結之前，NHS Digital也表達了一定會遵守TRE，因此TRE可被視為至少目前為止，討論英國個人健康資料應用在政策與規範上所不能忽略的概念。

不過究竟在法制規範與政策架構上要如何塑造出所謂保護隱私的「可證明的、可信的」方法，則相對地顯得眾說紛紜：在Goldacre Review中指出文獻上可能得到的建議例如獲得公眾廣泛支援為研究目的共享健康資料者，前提之一是資料利用人和管理該等分享行為的法規是值得信任的（trustworthy）。其可能的規範包括例如預先並持續地確認研究者之研究動機、資料近用面向採取的安全措施、研究是否係為公共利益、資料利用程序透明的程度，以及資料利用人是否需對資料濫用行為負責等。除了前揭關於規範與執行

111 就我國健保資料庫資料應用實況來說，早期國衛院提供之健保資料庫服務因為係健康資料應用之研究通過IRB審查後，研究人員可將資料直接攜出原本保有健康資料的機構，因此資料攜出後事實上已成為使用者能完全控制之資料。其後在健保資料庫憲法訴訟案判決時，則已經改為「衛生福利資料科學中心」方式，健康資料應用研究者向該中心申請於獨立作業區使用資料，採登入封閉網路的伺服器或主機上操作方式而無法將所利用之資料攜出，統計分析結果須交由審查員審查。許明暉，精準醫療年代的健康資料治理，國土及公共治理季刊，8卷3期，頁77-78（2020年）。

112 Goldacre & Morley, *supra* note 108, at 88.

113 *Id.* at 86.

114 See Mackenzie Graham et al., *Trust and the Goldacre Review: Why Trusted Research Environments Are Not about Trust*, 49 J. MED. ETHICS 670 (2023).

的條件外，TRE也有需要考量科技層面者，不過所有的可能提議都無法具有絕對的完整性：這是因為TRE需要針對應用健康資料的利用人以及個案作出不同調適，例如有些利用態樣只需要相對簡易的近用措施，而如果有好的科技擔保或許在程序上可以免除繁雜要求，因此一體適用（one size fits all）性質的TRE措施難以達成¹¹⁵。

二、英國資料法制的「轉向」？

由於英國原本為歐盟會員國之一，因此其資料法制的基本模式無庸置疑地建立在歐盟資料保護模式的基礎上。即便已然脫歐，英國仍然在與歐盟的經貿交流以及資訊流通的層面上緊密相關，因此亟需獲得歐盟GDPR的適足性（adequacy）認定。由於英國原本的2018年資料保護法（Data Protection Act 2018）本就奠基於GDPR以及其給予會員國的豁免與例外規範範圍，因此不太令人意外地歐盟個資保護委員會（European Data Protection Board, EDPB）認定英國2018年資料保護法中有關GDPR的適用及對英國資訊委員（Information Commissioner's Office, ICO）所賦予的權利及義務等現行英國國內資料保護的核心架構中，有關個資保護、處理及對於資料控制人要求及處理方式，符合GDPR的個資保護程度。另外，在LED方面，亦認定英國法律框架中的核心要件實質上與LED的基礎原則具有高度一致性¹¹⁶。

不過，畢竟英國已然脫離歐盟，並且由於NHS具有全民完整健康資料的特性，所以包括Goldacre Review與政府本身都認為對於該資料庫如能應用在科學研究甚至是商業領域，就社會與經濟層面來

¹¹⁵ Goldacre & Morley, *supra* note 108, at 105-06.

¹¹⁶ EDPB, Opinion 15/2021 regarding the European Commission Draft Implementing Decision pursuant to Directive (EU) 2016/680 on the adequate protection of personal data in the United Kingdom (Apr. 13, 2021).

說是極其重要的¹¹⁷，因此乃提出相關的「新方向」¹¹⁸資料再利用與共享政策及法制調整。然而，該等所謂「新方向」的本質，是否便意味著全然棄守歐盟資料保護模式以及資料法制的問題上呢？為了回答這個問題，本節將檢視依據TRE精神與資訊安全環境之相關政策與法制變革，是否就是一種脫離歐盟資料法制的「轉向」，亦或根本是迷途知返的「轉向」回歸。

英國政府在2022年4月所委託研究的Goldacre Review正式出版後，隨即根據這份報告內容，在2022年6月修正了原本在2022年2月提出的政府健康資料再利用於科學研究之政策提案：「資料拯救生命：藉由資料重塑健康及社會照護」(Data Saves Lives: Reshaping Health and Social Care with Data)¹¹⁹。該政策除了包括提供健康照護專業人員所需的最佳資訊，增進成人社會照護相關資料，向政策決定者提供相關資料，授權研究者所需資料以發展醫療技術，並合作發展有助於增進健康和照護的創新等強化健康資料應用優勢的內容外，其先決條件乃是第一部分所揭示的，需確保公眾對於其個人健康資料的再利用和共享能夠得到保障，尤其是在醫療和社會照護領域，並提高公眾對於此類資料使用的信任和滿意度。此外，政策亦旨在讓公眾了解其資料如何被使用，方便地存取和掌握其自身的醫療和照護資料，並有權選擇如何使用其資料，以確保公眾信任其資料會被安全地處理，對於其資料的使用有清晰的瞭解，包括個人

¹¹⁷ 在Goldacre Review中甚至也建議考量將健康資料加入數位經濟法之適用對象。Goldacre & Morley, *supra* note 108, at 171.

¹¹⁸ Department for Digital, Culture, Media & Sport (DCMS), *Data: a New Direction - Government Response to Consultation*, Gov.UK (June 23, 2022), <https://www.gov.uk/government/consultations/data-a-new-direction/outcome/data-a-new-direction-government-response-to-consultation#introduction>.

¹¹⁹ Department of Health & Social Care, *Data Saves Lives: Reshaping Health and Social Care with Data*, Gov.UK (June 15, 2022), <https://www.gov.uk/government/publications/data-saves-lives-reshaping-health-and-social-care-with-data/data-saves-lives-reshaping-health-and-social-care-with-data>.

照護以及改善整體人群健康、規劃、創新和研究等方面¹²⁰。再者，該政策的最後一部分則旨在發展正確的科技架構，內涵則是包括：(1)制定明確開放的標準，使資料能夠在維護資料隱私的前提下更安全、更有效率地被存取；(2)了解更廣泛的資料架構，以便建立和採購合適的系統；(3)產生明確的資訊安全指引，以確保技術架構系統和其中儲存的資料盡可能地安全；(4)理解並承諾減少系統和資料儲存對環境的影響，同時利用資料的力量減少健康和社會照護對環境的影響；以及(5)建立更有效和具有彈性的資料解決方案，例如選擇雲端儲存等¹²¹。

須注意者，相對於我國的資料應用行為經常是政策先行，法規緩修的狀態，基於法律保留原則，事實上英國在擬定與執行該政策之前，已經先行修訂了其健康資料整合¹²²與分享的授權基礎，從原本的2012年健康與照護法（Health and Care Act 2012）修正為2022年健康與照護法（Health and Care Act 2022），尤其在後者第二部分關於健康與成人照護之資訊（第92條至第101條）的授權基礎下，英國政府（衛生暨社會照顧部）將可以採取一系列措施，以更有效地蒐集、分析和利用健康與照護資料。在新的授權基礎下，公共醫療和成人社會照護機構即得向其他公共醫療和成人社會照護機構，或被委託提供健康和成人社會照護服務的提供者，要求匿名資訊（anonymous information）¹²³，以及允許衛生暨社會照顧部大臣要求所有受監管的成人社會照護提供者，提供有關其提供服務的資料¹²⁴。

2022年健康與照護法也明確規定在NHS England（原NHS Digital）認為需要或方便的情況下，允許其要求私人醫療保健提供

120 *Id.*

121 *Id.*

122 關於原本舊有Health and Care Act 2012與NHS資料整合之立法授權介紹，可參：何之行（註16），頁16-17。

123 Health and Care Act 2022, art. 96 (Eng.).

124 Health and Care Act 2022, art. 99 (Eng.).

者提供資料，以遵守衛生暨社會照顧部大臣的指示¹²⁵。最重要者，衛生暨社會照顧部大臣有權對提供健康和成人社會照護的私人和公共機構進行資訊處理標準的強制規定，以使資料能夠在系統中以可用的方式流動，同時，NHS England也被授權得發布強制性資訊標準¹²⁶。

綜上，NHS England在2022年健康與照護法的授權下，得以運行支持衛生和社會照護的關鍵國家資訊技術系統，以及蒐集、分析、公布和傳播衛生和社會照護服務產生的資料，以改善結果，因此實際上具有對NHS所蘊含全民健康資料完整應用的能力。從這些法制修正以及政策倡議面向來看，似乎英國對於健康資料法制有進一步或多或少想要脫離原本歐盟資料法制對資料利用的「箝制」，轉向更能活化利用健康資料於科學研究，更是創造數位經濟商業模式的態勢。然則，此次修法也帶來了一些質疑的聲音，例如該法案允許更多衛生暨社會照顧部得以控制NHS的可能性，甚至新增了138個衛生暨社會照顧部大臣之權力。與健康個資再利用與分享相關者，甚至允許衛生暨社會照顧部大臣使用次級立法來新創規範，更確認了NHS能數位化資訊的權力，可令NHS England與包括各種私人企業的第三方共享病患的健康資料，引發對病患隱私的擔憂¹²⁷。

不過，為了能夠盡量地消除這些可能的疑慮，避免過去的失敗經驗一再地輪迴，因此英國政府對於2022年健康與照護法新增授權的相關應用可能，基於Laura Wade-Gery的獨立評估報告¹²⁸提出五

125 Health and Care Act 2022, art. 98 (Eng.).

126 Health and Care Act 2022, art. 95 (Eng.).

127 *The Health and Care Act 2022*, PATIENTS4NHS, <https://www.patients4nhs.org.uk/the-health-and-care-bill/> (last visited Mar. 24, 2023).

128 Laura Wade-Gery即NHS Digital委員會主席，其評估報告主要是針對NHS的數位化轉型進行整體評估。該評估報告的主要重點包括改善數位基礎設施、整合數位系統、強化員工管理與保護患者資料的技能、引入新興技術以及保護病人隱私與資料安全。整體而言，該評估報告認為數位化轉型可以提高NHS的效率和患者的滿意度，但同時需要確保數位資料的安全和隱私。Laura

個保證：(1)利用資料提高醫療服務品質和對患者之療效；(2)確保資料的保護、安全、尊重和適當利用，維護患者的選擇權；(3)提供員工訓練和支持，維護最高標準的資料保護，並強化資料管理流程和治理；(4)建立透明和負責的資料保護機制，獲得獨立專家的建議和監督，確保作為資料安全港的角色；以及(5)運用最佳技術和不斷創新，支持資料安全等。

就以上法制變革以及相關政策與執行說明文件來看，本文認為與其將其新近資料應用法制解釋為「轉向」，毋寧應將此等新方向解作在符合信任關係的條件下，將（健康）資料應用規範的模式回歸到歐盟資料模式的懷抱。之所以應為此解，係因：

（一）將TRE之信任擔保責任作為健康資料再利用與共享的前提

綜觀英國NHS健康資料再利用的歷次失敗經驗，主要的問題癥結都一直圍繞在於缺乏令人信服的「可證明的、可信的方法來保護患者隱私」。除了care.data與GDPR在執行上的失敗經驗外，在NHS Digital決定大幅將資料數位化的過程當中，其自身的委員會召集人也在評估報告中提出，在構想上的數位策略以及實際上基礎設施的責任必須要一致，而能令資料控制人與利用人擔負責任，以避免當時仍然處於二者分離的態樣，在管理與規劃上造成摩擦¹²⁹。

再者，Goldacre Review中則以TRE作為可證明與可信之方法而為信任之擔保，令資料控制人以及資料利用者負擔責任，以符合資料保護中的課責（accountability）原則。於現行的NHS England在實際的TRE落實中，則一改過去兩次失敗經驗之沉痾¹³⁰：

Wade-Gery, *Putting Data, Digital and Tech at the Heart of Transforming the NHS*, Gov.UK (Nov. 23, 2021), <https://www.gov.uk/government/publications/putting-data-digital-and-tech-at-the-heart-of-transforming-the-nhs/putting-data-digital-and-tech-at-the-heart-of-transforming-the-nhs>.

¹²⁹ *Id.*

¹³⁰ *Protecting and Safely Using Data in the New NHS England*, NHS ENGLAND,

1. 課責原則與透明原則之再強調

在實踐透明原則上，NHS England將透明公開哪些組織獲准近用資料、其近用之資料為何、近用目的以及使用的資料，亦將公布有關內部和外部資料近用的獨立建議和相關決策。

在課責原則的資料近用程序保障上，將建立清晰的規則和流程，確保內部和外部資料近用和利用的決策都在明確的資料治理框架內下完成，並經驗證、審查以及委員會之監督。在資料近用的組織保障上，則以首席交付官（chief delivery officer）作為高級資訊風險官（senior information risk officer, SIRO），以負責資訊風險政策，並納入資訊治理功能和資料保護官（information governance function and data protection officer）以及網路資訊安全人員等，而為患者之資料保護與資訊安全提供層層交錯之保障。再者，為釐清資料治理責任問題，因此將負責資料治理的委員會委員及對於相關資料蒐集、處理與利用之人加以區隔，以確保前者能夠對後者進行資料功能的監控與監察的獨立性。除了內部的資料保護官以外，在NHS外部則由資訊委員（information commissioner, IC）以及NDG加以監督。

2. 提高資料共享環境中的去識別措施強度，以證明科學研究操作環境之可信任性

對於所有用於規劃、委託和科學研究目的之資料近用來說，由於很多資料的處理不需要特定個人的身分識別，因此只有在必要時才會使用識別因子，故NHS England將在可能的情況下優先使用去識別化的資料。另外，因為幾乎所有資料的利用都可以在NHS內部完成，不需要移動至外部，故除非絕對必要，將不允許資料移出系統。

(二) 將健康資料再利用與共享條件清楚地規範，以克服告知後同意的實踐問題

由於在兩次的健康資料再利用政策失敗經驗中，均發現現行的退出系統對部分大眾來說難以理解和使用，因此英國衛生暨社會照顧部（DHSC）將與NHS England、NDG和其他利益相關方合作，以確保病人對退出系統值得信任，並確保資料繼續支持健康和照護系統的運作。

除了在健康資料領域的利用規範外，英國自2022年提出資料保護與數位資訊法草案（Data Protection and Digital Information Bill），希望能以較有「彈性」之方式更新與簡化英國的資料保護架構，以修正英國現有的2018年資料保護法與UK GDPR。其中較明顯處例如草案第5條對UK GDPR的合法處理（lawful processing）原則新增合法性之態樣，亦即可為被政府認可之合法利益進行個資處理，並新增新的附件作為相關被認可合法利益之要件。對於這個新增的合法處理要件，基於避免未來實際進行權利衡平時出現困難之理由等原因，草案也授權國務卿得修改附件內相關要件，以使政府能夠以迅速行動來應對不同狀況之能力。不過，本文認為所謂的放寬與彈性，似僅是將GDPR原本即授權會員國可為例外規範與豁免之部分予以明文化，以求掙脫原本過度依賴個人同意之實務操作難題。但即便如此，在目前的審議過程中，英國上議院也對該草案部分內容提出不同意見。以前揭的草案第5條為例，上議院便指出資料處理合法性原則係個資保護規範之核心，不應任意藉由行政命令類型之授權加以變更¹³¹。

131 U.K. HOUSE OF LORDS, 10TH REPORT OF SESSION 2023-24 - DELEGATED POWERS AND REGULATORY REFORM COMMITTEE, DATA PROTECTION AND DIGITAL INFORMATION BILL PEDICABS (LONDON) BILL, paras. 3-7 (2024).

歸納來看，事實上英國政府一直以來都積極地想要促成健康資料至少在科學研究面向上的再利用與共享，只不過在經歷了一再的失敗經驗以後，本文認為在新的法制當中至少不斷地強調三個核心價值以作為實現健康資料再利用與共享的先決條件：必須以保護個人資料權利與隱私作為先決要件、導入TRE作為信任擔保，以及良好的社會溝通以獲得大眾信任。本文認為該等先決要件的要求，其實都與歐盟資料策略政策以及資料治理法之規範架構與內涵相符¹³²，而所謂的在個資保護面向上的放寬與彈性，探究其規範內容，僅是將GDPR原本即授權會員國可為例外規範與豁免之部分，以立法方式滿足法律保留與法律明確性之要求，使之成為目的外利用之合法事由之一，而脫離舊有過度依賴個人同意的泥沼罷了。再者，積極地嘗試對於NHS之健康資料再利用於科學研究，本來就是英國政府一直以來的重點政策目標，因此轉向之說當有其誤會，而應認係以更可行的方式，達成原本期待的目標。

肆、臺灣健康資料再利用法制

在本文嘗試分析歐盟資料法制與英國政府的健康資料再利用與分享政策、法制以及實際經驗後，接下來本文將回到我國健保資料庫案來看，首先提出在憲法法庭關於健保資料庫案判決以及有關機關提出回應說明中，所可能尚待省思之處，其後提出資料驅動科研再利用法制的建議方向。

一、健保資料庫案判決所給的重點與可能的誤區

健保資料庫案中憲法法庭在主文一指出：個人資料保護法第6條第1項但書第4款的健康資料目的外再利用於科學研究之相關規定

¹³² 翁逸泓（註80），頁70-71。

與法律明確性原則、比例原則尚屬無違，因此並不牴觸憲法第22條保障人民資訊隱私權之意旨。本文認為此間或許仍有以本文前揭比較法與論證為基礎而探究之餘地，並將討論焦點集中於兩點：其一，系爭去識別化措施的本質究竟為何；以及其二，學術研究與公共利益，以及個人資料權利之間的關係為何。

（一）主文一的「去識別化措施」要求並不足以作為信任擔保

1. 關於「去識別化的義務」所要討論的該是什麼？

在憲法法庭111年憲判字第13號判決中，大法官們在處理關於個資法第6條第1項但書第4款「無從識別特定之當事人」相關爭議問題時，首先就據以審查的憲法權利在法律明確性原則之部分，先以解釋¹³³之方式出發，認為所謂「無從識別」的範圍應當落在「完全匿名且無還原可能性」之非個人資料（學術研究範圍最下限），以及毫無去識別措施的「可直接識別該個人」（學術研究範圍最上限）之間¹³⁴。不過，既然已在明確性原則部分以體系解釋之方式釐清了個資法第6條第1項但書第4款「無從識別特定之當事人」係一個具有上、下限範圍光譜式的「有間接識別可能性」概念，那麼似

¹³³ 在該判決段落中，憲法法庭的解釋是：「而系爭規定一以『無從識別特定之當事人』為利用病歷、醫療、基因、健康檢查等個人健保資料之條件，『無從識別特定之當事人』之文義，首可明確排除『可直接識別該個人』之資料型態；又與個資法第2條第1款規定之個資定義合併觀察，亦可排除『完全匿名且無還原可能性，因此不在個資法保護範圍內』之資料型態。」（粗體字為本文強調）。

由於在解釋系爭規定一（個資法第6條第1項但書第4款）的時候如果採取個資法第2條第1款規定之「得以直接或間接方式識別該個人之資料」的嚴格文義要求的話，則在「可直接識別該個人」之部分的解釋會導致與系爭規定一的規範相互矛盾，因此不採原本「得以直接或間接方式識別該個人之資料」之嚴格文義解釋方式，而予以限縮。另方面，對於系爭規定一如果採取排除掉「完全匿名且無還原可能性，因此不在個資法保護範圍內」類型之解釋，則能與個資法第2條第1款規定之「得以直接或間接方式識別該個人之資料」相互支持。如此來看，或許這個解釋的方法在文義解釋確定範圍之後，即採體系解釋之方法處理。

¹³⁴ 憲法法庭111年憲判字第13號判決段40。

乎在關於比例原則的討論當中，卻又舉出「或有主張將個人健保資料處理成為完全不具還原識別可能性之匿名資料再予利用，同樣能達成系爭規定一之法定目的等語……」¹³⁵，則容有討論空間。這是因為由聲請人方相關聲請意旨觀察，聲請人所謂¹³⁶：

……依有權機關之解釋，透過代碼連結比對而得間接識別特定當事人之情形，仍符合系爭規定一關於無從識別特定當事人之要件；聲請人無意摧毀健保資料庫之完整性，但依系爭規定一，為學術研究之目的即一律得就尚有間接識別可能性之個資為目的外利用，未區分不同公益重要性，與比例原則仍有未符……（粗體字為本文強調）

似乎並不特別否認個資法第6條第1項但書第4款「無從識別特定之當事人」在事實上「尚有間接識別可能性」。又，細察聲請方理由書，其對此明確表明個資法第6條第1項但書第4款「無從識別特定當事人」的判斷標準應該以利用行為中的資料提供者或資料蒐集者判斷，因此邏輯上可以清楚地看出聲請人接受這個「無從識別特定當事人」是有一個範圍的「仍有間接識別可能的無從識別當事人」，並且正因為應限縮解釋為「仍有間接識別可能的無從識別當事人」，所以才能仍落在個資法第2條第1款規定之個資定義之保護範圍內，也才有聲請人所謂權利保護之必要以及訴之利益。從而，難以想像聲請人會以如此自打嘴巴的方式，提出「或有主張將個人健保資料處理成為完全不具還原識別可能性之匿名資料再予利用，同樣能達成系爭規定一之法定目的等語……」的理據¹³⁷。

¹³⁵ 憲法法庭111年憲判字第13號判決段56。

¹³⁶ 憲法法庭111年憲判字第13號判決段25。

¹³⁷ 事實上，遍查聲請人方之釋憲聲請書相關的頁41-45部分，聲請人方似亦未有如此之主張。

本文認為真正的爭執核心所在，毋寧應是聲請方認為「更關鍵的問題在於」對資料控制人的問責要求，並且認為這樣子的規範方式應該被認為是資料安全的依據，而不是一個限制個人資訊自主與資訊隱私權的合法性基礎¹³⁸。據此，與其提出「或有主張需要達到不可回復的完全去識別」之態樣作為稻草人攻擊而混淆爭點，或許分析之標的毋寧應聚焦在對於該等範圍光譜式的健康個資，應該依照利用的公共利益之不同重要性予以區別對待而為不同強度之保障，並且確認此等「去識別化的義務」之責任歸屬與擔保。

2. 對（資訊）隱私之概念不應採限縮內涵之解釋

復次，在健保資料庫案判決中所指只需去識別化手段「已足大幅降低蒐用個人健保資料所生之個人資訊隱私權所生之侵害」¹³⁹，在某一程度上實與英國在1999年的*Source Informatics*案中，法院以普通法之角度認定即便為資料特定目的外之利用，只要分享予第三方時已經有一定程度的「匿名化」即為已足，有本質上相似之處。雖然，在*Source Informatics*案中因為法律變更的關係，無從得知是否在引入歐盟資料法制模式後，同案會有不同結果；然則，在該案中關於去識別化的問題，學者認為除了不應當僅只考量保密義務的問題外，並且在考量關於（資訊）隱私的層面時，亦不得將其為限縮內涵（*narrow conception*）之解釋¹⁴⁰。

質言之，在本案中如果僅考量以資訊安全方式降低所生侵害的個人權利風險，而未將隱私之概念以複合式內容（*umbrella term*¹⁴¹）

138 憲法法庭111年憲判字第13號判決憲法解釋聲請理由書（三），頁14-19。

139 憲法法庭111年憲判字第13號判決段54。

140 Beyleveld, *supra* note 95, at 155-56.

141 Daniel J. Solove教授提出這個觀點時，認為隱私這個複合概念「指涉一個廣泛（*wide*）且不同的相關事物群組，並且，這個概念不能脫離社會之脈絡而獨立地加以理解，這是因為隱私在其核心本質上是一種社會創造物，如果沒有社會的背景，就不會有隱私的需求」（粗體字為本文強調）。Daniel J. Solove, *A Taxonomy of Privacy*, 154 U. PA. L. REV. 477, 485, 488-91 (2006).

觀察，排除內含的公共利益以及系爭個人與他人發展外部關聯可能時，則已然採取較限縮範圍之隱私內涵觀點。這個觀點事實上亦符合歐洲人權法院¹⁴²一直以來對於隱私權利應為擴張解釋其內涵之詮釋角度¹⁴³，例如「……尊重個人生活也必須在某種程度上包括與其他人建立和發展關係的權利（“[r]espect for private life must also comprise to a certain degree the right to establish and develop relationships with other human being”）」、「將這一概念僅限於個人得依其選擇生活方式的『內生性』意涵之內，而完全將這個概念排除前者以外之外部世界，將是過於狹隘的（“it would be too restrictive to limit the notion to an ‘inner circle’ in which the individual may live his own personal life as he chooses and to exclude therefore entirely the outside world not encompassed within that circle”）」¹⁴⁴。

又，限縮內涵隱私概念的支持者除了傾向於將隱私權視為單純之個人利益，而將受益於科技進步的權利視為普遍公共利益外¹⁴⁵，實證研究並指出狹隘的隱私和資料保護概念將導致缺乏機制來確保有效的個人資料保護問題¹⁴⁶。這是因為如果僅只將隱私以如同 *Source Informatics* 案的限縮範圍解釋，那麼由於隱私的概念無法涵括較廣之公共利益，便較容易發生個人利益（狹義隱私權利的利

¹⁴² 由於歐盟會員國均為歐洲理事會之成員國，因此歐盟法院以及歐盟在關於人權（包含私生活權利之保障）的事務上，均會「尊重」（respect）歐洲人權法院之裁判。

¹⁴³ Bert-Jaap Koops et al., *A Typology of Privacy*, 38 U. PA. J. INT'L L. 483, 493-94 (2017).

¹⁴⁴ Niemietz v. Germany, App. No. 13710/88, ¶ 29 (Dec. 16, 1992), <https://hudoc.echr.coe.int/eng?i=001-57887>; Costello-Roberts v. United Kingdom, App. No. 13134/87, ¶ 6 (Mar. 25, 1993), <https://hudoc.echr.coe.int/eng?i=001-57804>; Peck v. United Kingdom, App. No. 44647/98, ¶ 57 (Jan. 28, 2003), <https://hudoc.echr.coe.int/eng?i=001-60898>.

¹⁴⁵ Beyleveld, *supra* note 95, at 155-56.

¹⁴⁶ Daniel Guagnin et al., *Privacy Practices and the Claim for Accountability*, in TOWARDS RESPONSIBLE RESEARCH AND INNOVATION IN THE INFORMATION AND COMMUNICATION TECHNOLOGIES AND SECURITY TECHNOLOGIES FIELDS 99, 103-04 (René von Schomberg ed., 2011).

益）與公共利益（科學研究進步成果之利益）之衝突角力。此等潛在衝突可能性在一定程度上將導致產生前揭兩個利益難以併存，或是如果要強化其中一個利益（例如個人利益），必定將減縮另一個利益（例如促進科學研發公共利益）的謬解。

準此，在健保資料庫案中，如果在比例原則上僅考量對於「個人資訊隱私權」可以用去識別化措施大幅降低風險，或許並未同時適切地考量隱私概念中關於該個人與他人可能產生外部關係之可能性。換言之，如果在科學研究中將去識別化措施認為是「限制資訊隱私」的合法性基礎，那麼即便去識別化措施有其效果，然則就科學研究之結果如伴隨出現因為基因而生之歧視或偏見問題時，即生對於資訊隱私之侵害。須注意者，本文所採取的這個觀點，並不是指相關之去識別化措施是毫無意義的，而是去識別化措施所擔保者，應僅是以資訊安全作為信任之擔保，而不是對於個人資訊隱私權之擔保。

3. 揚棄對於「去識別化措施」本身的糾纏

那麼，個資法第6條第1項但書第4款「無從識別特定之當事人」從廣義內涵的隱私概念出發，又應如何看待？

由於如同在大法官們於健保資料庫案中所論證的，即便是個資法第6條第1項但書第4款「無從識別特定之當事人」在文字上規範「無從識別」，在解釋上仍必須解為「存在間接識別的可能性」，因此即便是經過去識別化的措施，在定性上必然仍屬於得間接識別特定個人的個人資料，而為個資法規範標的。雖然，在法律層面上區分可識別與去識別個資或許有其區別實益，然而，在科技領域中，由於資料科學技術的快速發展與實際應用，所以即便是被視為英國在政策上趨向盡量開放生醫健康研究的Goldacre Review，也特別指出「假名化措施」（即在我國健保資料庫案中的「去識別化措施」）在實際上當用於NHS一樣詳細的醫療紀錄時，是很容易再識別

的：假名化資料的再識別風險會隨著資料集涵蓋更多人口比例和資料集變得更加詳細而增加；另外，就蒐集、處理與利用全人口的巨量詳細健康資料的再利用與分享行為中，當可以近用資料的人數增加時，必定伴隨增加不可信的資料利用者（不論該等資料利用者主觀上是否具備故意），也會使得資料風險增加¹⁴⁷。因此，這種二分法已經難以再為精準而明確地適用，有論者便對此認為，無論個資是否為可識別者，都應視為可識別的個資，並根據可識別個資的特性在法律上進行處理¹⁴⁸。

本文認為，由於在考量健康資料為科學研究而再利用時，必須超越個人權利之觀點以符合廣義內涵的資訊隱私概念，因此與其糾纏在去識別化措施本身的概念釐清，不如將重點放在究竟去識別化後的健康個資，應當如何再利用，尤其是如何令資料控制人等負擔合比例之責任的問題。再者，如果僅僅單純只分析個資法第6條第1項但書第4款「無從識別特定之當事人」之文字，則在健保資料庫案判決當時的運作，面對沒有足夠的法制與組織（111年憲判字第13號判決主文二部分參照）對於個資當事人控制可能性而為信任擔保的事實，或許更是不足夠。

（二）個資法現行對於不同學術研究、不同公益重要性與人民權利可能受影響不同程度之區分與比例原則之權衡

在健保資料庫案判決中，關於主文一部分的審查標準¹⁴⁹，憲法法庭很正確地認為應採較過去司法院釋字第603號解釋指紋錄存案的解釋中，關於指紋個資蒐集更高之嚴格標準予以審查¹⁵⁰，不過隨

147 Goldacre & Morley, *supra* note 108, at 85-86.

148 ADAMS ET AL., *supra* note 88, at 154-55.

149 憲法法庭111年憲判字第13號判決段45。

150 歐盟對此亦採取嚴格審查標準。EDPB, Guidelines 03/2020 on the processing of data concerning health for the purpose of scientific research in the context of the COVID-19 outbreak, para. 27 (Apr. 21, 2020).

即在憲法法庭111年憲判字第13號判決的第48段中，憲法法庭認為本案個資法系爭規定所生的基於科學研究等目的，基本上符合特別重要公益目的之標準。

如果要繼續分析憲法法庭是如何權衡判定符合特別公益之標準而令個人資料權利退讓，那麼首先要辨別出系爭權利與公共利益為何：本案中所牽涉者，至少包含個人資料權利以及享受科研進步成果利益之權利等。

其中，享受科研進步成果利益之權利這個概念，或許在我國法制的理解脈絡下，需要更進一步的釐清：這個依照公民與政治權利國際公約及經濟社會文化權利國際公約施行法¹⁵¹所保障之權利，似乎在憲法法庭的健保資料庫案中並未有明白揭示，而是代以「統計或學術研究累積科學知識技術等公共財，諸如發現或確認辨識疾病有效治療方法，以提升醫療與公共衛生之目的」¹⁵²之語句表達該特別公共利益，指出其「基本上尚難即謂不符特別重要公益目的之標準」。不過這邊必須要加以區分者，乃是前揭「享受科研進步成果利益」的特別公共利益，以及「給予個人以及（或）團體增長與取得知識的科學權利」¹⁵³仍有所不同¹⁵⁴，而後者似乎僅只屬於個人之利益範圍。就此，論者認為由於後者——科學研究之結果，可為前者所涵括，因此將二者統稱為科學權利（right to science）¹⁵⁵。

151 公民與政治權利國際公約及經濟社會文化權利國際公約施行法第2條、經濟社會文化權利國際公約第15條參照。

152 憲法法庭111年憲判字第13號判決段48。

153 在此並非指的是每個人都能夠成為科學家或研究者，而是每個人都能為了其個人發展，而有機會成為研究者，以利用及反思其本有的知識。See Mylène Bidault, *Considering the Right to Enjoy the Benefits of Scientific Progress and Its Applications as a Cultural Right: A Change in Perspective*, in *THE RIGHT TO SCIENCE: THEN AND NOW* 140, 140-49 (Helle Porsdam & Sebastian Porsdam Mann eds., 2021).

154 Helle Porsdam & Sebastian Porsdam Mann, *Introduction*, in *THE RIGHT TO SCIENCE: THEN AND NOW* 1, 4-5 (Helle Porsdam & Sebastian Porsdam Mann eds., 2021).

155 See Cesare P. R. Romano, *The Origins of the Right to Science: The American*

然則科學權利之核心焦點，除了在科學研究者本身獲取知識以及獲得科研成果後之應用的雙重作用以外，關於如何可能確認科技發展之潛在有害影響，並加以最小化甚至避免，亦應為焦點之所在¹⁵⁶。例如，以資料驅動之科學研究來說，相應的重點即應是在健保資料庫案中對於資料當事人資訊權利侵害之防免¹⁵⁷。

然則在該案的辯論過程中，事實上對於此點有個相當重要的爭點：是不是所有的學術研究目的，都會落在特別重要公共利益的範圍內，以及如果僅只落在一般公共利益的範圍內，那麼人民所受影響之權利有沒有可能因為有機會事先加以評估，進而以法律或其他方式更清楚地加以區分¹⁵⁸。可惜，由於在判決中短短的論理文字：

……即憲法已明示國家有促進衛生與醫療之責任，系爭規定一寓有透過統計或學術研究累積科學知識技術等公共財，諸如發現或確認辨識疾病有效治療方法，以提升醫療與公共衛生之目的，是系爭規定一所稱基於醫療、衛生之統計及學術研究目的，基本上尚難即謂不符特別重要公益目的之標準。

似無法直覺地尋得以嚴格之審查標準作為憑恃，而得到符合比例原則的推論與判斷理由，因此本文以系爭判決主文一結論中，似較傾向支持的機關方相關論辯文件，嘗試尋得相關立論理據，並加以分析。

Declaration on the Rights and Duties of Man, in THE RIGHT TO SCIENCE: THEN AND NOW 33, 33-53 (Helle Porsdam & Sebastian Porsdam Mann eds., 2021).

¹⁵⁶ Porsdam & Porsdam Mann, *supra* note 154, at 4.

¹⁵⁷ Postan, *supra* note 85, at 229-31.

¹⁵⁸ 在此需要注意的是，憲法法庭就此爭點在實際操作的面向上，已然明確表達「應由一定之獨立監督機制，依申請個案之相關情狀作嚴格之審查」（粗體字為本文強調）。憲法法庭111年憲判字第13號判決段48。

1. 近觀個資保護上的學術研究特權條款

我國個資法有權解釋機關在健保資料庫案中，對於聲請人就比例原則上關於個資法規範本身對：(1)不同學術研究、(2)不同公益重要性與(3)人民權利可能受影響不同程度未有區分之爭點，認為個資法¹⁵⁹已在：(1)學術研究目的上，就一般個資與特種個資區分；(2)就一般個資與特種個資之使用目的言，區分一般公共利益與衛生、醫療或犯罪預防等重大公共利益之不同公益重要性；(3)相關條文均明定為統計或學術研究目的而有「必要」，係指個資法第5條關於比例原則之規定，尤其是侵害個人權利最小原則。並且，由於個資法相關條文已規定「無從識別特定當事人」，再加上比較法上參酌各國一般性個資保護法，也多採與我國個資法相仿之立法模式，因此認為並無比例原則之違背¹⁶⁰。

然則，如果回顧本文第貳、二部分可以發現在處理（健康）個資再利用與資料分享行為時，就蒐集、處理與利用特定目的以及影響當事人權利及公共利益之間的比例衡平者，所需要考量之要素以及對應之原則會是依據風險為本（risk-based）的個人資料權利侵害最小原則，以及相對的同樣基於風險為本考量的課責原則，而導致不同的資料控制人／資料受託人責任。在GDPR中，風險為本之考量是很重要的一個概念，主要目的是確保個人資料的保護適當地配合風險程度，並且讓相對應的保護措施與風險程度相符合。究其基礎，乃是與歐盟基本權利憲章第52條有關比例原則之規範連接，而此處的風險（risk）與資料控制人以及個資專責機關在GDPR下的一般責任相關聯而必須負擔符合比例之責任¹⁶¹，因此亦與課責原則相

159 此處相關之個資法條文為：第6條第1項但書第4款、第16條但書第5款、第19條第1項第4款，以及第20條第1項但書第5款。

160 國發會（110）發法字第1102000017號函（註77），頁7-11。

161 BRENDAN QUINN, DATA PROTECTION IMPLEMENTATION GUIDE: A LEGAL, RISK AND TECHNOLOGY FRAMEWORK FOR THE GDPR 3 (2021).

關，而形成課責為本（accountability-based）之資料保護模式。依據歐盟前資料保護監察官（Data Protection Supervisor）Peter Hustinx在審視關於歐盟個資保護指令與當時GDPR提案之論述指出，以風險為本的模式應當在風險更高的地方應用更細緻的責任，而在風險更低的地方應用較輕的義務。如此一來，不僅可以讓合於規範性之執行集中在最需要的領域（例如依據資料的敏感性或特定處理操作的風險），也意味著可以以更「輕鬆」的方式處理風險最小的領域¹⁶²。

2. 現行個資法的學術研究相關條款，真的能夠回應比例原則的要求嗎？

如果依循本文的思考脈絡要回答這個問題，那麼要問的問題或許會變成是：為什麼我國現行個資法的區分個資使用目的以及不同公共利益方式，與同時被有權解釋機關所提出的GDPR第89條的為公共利益之學術研究而為個資目的外利用規範¹⁶³，其實根本應該是不同的兩件事呢？

本文認為，這是因為我國的個資法雖然在主要架構上移植的是歐盟個資保護模式，但是所承繼的版本卻是基於歐盟個資保護指令（Directive 95/46/EC），而不是在2016年已然更新思維的GDPR；但是有權解釋機關卻在健保資料庫案中，錯將我國現行個資法規範體系與GDPR第89條相比，因此發生誤解¹⁶⁴。細究之，我國個資法以之為本的歐盟個資保護指令，「僅」是鼓勵會員國內立法應特定高風險類型之個資蒐集處理與利用，也就是區分較易侵害個人權利的

¹⁶² Peter Hustinx, *EU Data Protection Law: The Review of Directive 95/46/EC and the Proposed General Data Protection Regulation*, EUROPEAN DATA PROTECTION SUPERVISOR (Sept. 15, 2014), https://edps.europa.eu/data-protection/our-work/publications/speeches-articles/eu-data-protection-law-review-directive_en.

¹⁶³ 國發會（110）發法字第1102000017號函（註77），頁9-10。

¹⁶⁴ 同前註。

特種敏感個資與一般個人資料¹⁶⁵，但卻不明確要求資料控制人／資料受託人擔負不同程度之責任。不過，原本個資保護指令的規範方式，由於區分的標準僅只是一般與特種個資，因此就特種個資為目的外利用之科學研究行為時，則必須要不分可能影響個人權利風險強弱的科學研究型態，全部都要以高規格方式對待，則事實上對於個資控管者在行政與經濟成本等法遵負擔上反倒較高¹⁶⁶。相對的GDPR所考量者乃是以風險為本之模式加以替代，因此在程序上以及對應監督控管的組織上則聚焦於依據風險的可能性與嚴重性，考量個資處理（利用）之本質、範圍、脈絡、目的以及風險來源，而為不同之評估與對待¹⁶⁷。並且，這個風險為本的模式，又進一步地反映在課責原則的考量核心當中加以規範。

本文認為現行的個資法採取歐盟資料法制模式的方向是正確的，但是現存架構對於保障個人資料權利以及公共利益有其侷限，究其所以，實乃其規範之核心並未以風險為基礎：

- (1) 現行法律僅透過傳統上區分不同學術研究和不同公益重要性的方式來衡平個人資料權利與公共利益，但這並不足以真正地反映人民個資權利可能受到的風險，也難以符合比例原則的實質判斷。究其原因，資料科學的快速進步導致固定僵化的去識別化措施可能無法有效阻卻辨識風險。此外，政策上仍期待在科學研究後之發現能進入產業應用以及政府循證決策，從而必須考量資料控制人（機關）和其後資料中介者對於個資利用的風險控管能力和責任，以避免侵害個人個資權

¹⁶⁵ Directive 95/46/EC of the European Parliament and of the Council of 24 October 1995 on the Protection of Individuals with regard to the Processing of Personal Data and on the Free Movement of such Data, recital 53, 1995 O.J. (L 281) 31, 36.

¹⁶⁶ Joachim Schrey, *General Conditions for Data Processing in Companies under the GDPR*, in NEW EUROPEAN GENERAL DATA PROTECTION REGULATION: A PRACTITIONER'S GUIDE 105, 115-16 (Daniel Rücker & Tobias Kugler eds., 2018).

¹⁶⁷ GDPR recital 89.

利和不特定多數資料當事人之群體隱私 (group privacy) 權利¹⁶⁸。因此，對於侵害權利的來源與強度已然與原本個資法規範當時時空狀況有所不同，既然資料控制人以及有關機關之相應資料控制能力已然因為科學技術進步而提升，從而在思維上當然應接受不同的監督方式以及責任要求，而不能僅滿足於一般／特種資料以及一般／重大公益的區分方式，作為權利防護機制。

(2)現行以個資保護指令時期為基礎的個資保護法律框架，在信任關係的建構中，焦點雖然在於強化透明原則，但是卻是將透明原則本身作為單一目的，因此會看到我國個資法在透明原則的安置上，採取的是揭露與通知的系統策略，亦即主要對應在個資法第3條第1、2款的查詢、請求閱覽與請求製給複製本（揭露），以及同法第11條至第13條，第19條第2項的通知規範。

168 資料保護法制與資訊隱私權息息相關，而歐盟的資料保護規範在保護個人基本權利之價值觀影響下，亦與歐洲人權公約具有緊密關聯。不過由於在歐洲人權公約的體系下，大多數關於公約第8條涉及私人生活、家庭生活、住所和通信權的內容等私生活權利保護相關案件之重點，較集中於個人及其權利和利益。究其原因，依歐洲人權法院的觀點，隱私與個人價值密切相關，因此原則上只有自然人才能向法院提出對於該權利的侵犯，因此法人／團體無法就隱私權的侵犯提出申訴。然則，在學術論理上關於隱私權之概念範圍除了個人權利之態樣外，學者認為「關係人隱私」(relational privacy)或「家庭隱私」(family privacy)，也就是個人與他人建立關係和發展家庭聯絡之利益在某些情況下，亦被視為一種群體隱私權 (group right to privacy)。Linnet Taylor et al., *Introduction: A New Perspective on Privacy*, in *GROUP PRIVACY: NEW CHALLENGES OF DATA TECHNOLOGIES* 1, 8-11 (Linnet Taylor et al. eds., 2017).

這個學術上論理之觀點如果加以延伸，則對於個人隱私之侵害如若可能對某一相關群體 (group) 產生影響時，後者應可被視為對群體隱私權之侵害。本文認為這在對於個人健康資料之侵害更為明顯，這是因為對於個人健康資料之侵害可能連帶地使與之擁有共同生物特徵或基因特徵之群體受到不利益。基此，隱私保護主要針對個體，但現代技術的發展讓我們必須重新審視對於資訊隱私的理解。尤其當涉及群體和其資料保護時，該等轉變即不僅應考慮個人的隱私權，亦須考慮群體層面的隱私保護。

相對地，以風險為本的規範架構，就透明原則來說，其規範安置之目的在於作為信任基礎的擔保，因此透明原則不惟是僅對於透明作為本身的目的擔保，更是支持資料當事人對於理解資料控制人所控制的資料處理系統和決策背後的理由，以及確保資料處理系統和決策的公正性，而終極地達成強化信任的目的（例如GDPR第22條第3項要求資料控制人應執行適當保護措施以確保資料當事人之權利、自由及正當利益）。換言之，透明原則在此有雙重目的：確保透明本身，以及藉由透明的作為（揭露與通知）來降低個資風險，以擔保資料當事人對於資料控制人的信任。因此透明原則應當被重新定義為監管和系統設計的一個信任擔保工具，而不是最終目標：最終極的目標應當是降低個人資料權利與公共利益受到侵害的風險，而不是僅僅止步於已經履行了揭露與通知的作為本身。

- (3)再者，就解釋機關援引GDPR第89條證明國際上相關立法例與我國相似部分，事實上該條所規定的是要求要確保技術與組織上措施能夠用以確保資料最小蒐集原則，以達到降低侵害風險之目的。從而，只要是能用以確保資料最少蒐集原則之落實，那麼這些信任擔保的措施「可以包括假名化」，因此假名化措施反倒不一定是必要的（本文前揭分析中，也建議能揚棄對於去識別化措施本身的糾纏），真正的重點反倒應該是在於能夠以個案的具體風險為判斷依歸，而確保個資當事人的資料權利受到最小的侵害可能。

3. 學術研究真的無法事先區別不同領域公益重要性，或預見未來對人民可能造成的影響，並以法律具體規範嗎？

按關係機關在憲法法庭健保資料庫案言詞辯論後之補充回應，在「各國一般性個資保護法對為公共利益之學術研究目的運用個資

多採與我國個資法相仿之立法模式」部分，指出GDPR前言第33點與第159點對於當事人對「符合標準」之科學領域容許給與廣泛同意，以及對以科學研究為目的之個資處理應採取廣泛解釋，固為正解¹⁶⁹，然就其後演譯推論而得出之以下論點，容有探究空間¹⁷⁰：

……爰相關外國立法例，均未區分不同學術研究之公益重要性，作為限制當事人資訊隱私權之基礎，究其原因應係學術研究領域涵蓋甚廣，且其本質係為探求未知的知識，實難事先一一區別其不同領域之公益重要性，或預見未來對人民可能造成的影響，並進而以法律具體規範之。（粗體字為本文強調）

首先，在該段推論之前提，即GDPR前言第33點¹⁷¹中所指為科學研究目的所處理個資時，於個資蒐集時可能因為學術領域廣泛且具有一定程度不確定性，因此通常難以「完整」（fully）辨識該等處理之目的，不過這句話的意思，當然並不是說關於科學研究之目的是完全不用事先辨識而特定的。

169 除了GDPR為此等擴張之解釋方法外，聯合國之相關建議，亦為如此之解釋方法。Joseph A. Cannataci (Special Rapporteur), Rep. of the Special Rapporteur on the right to privacy, U.N. Doc. A/74/277, section 15.5 (Aug. 5, 2019) [hereinafter U.N., Privacy Rapporteur Report].

170 國發會（110）發法字第1102000017號函（註77），頁10。

171 GDPR前言第33點：「為科學研究目的所為之個人資料處理，於資料蒐集當時，通常不可能完整指明該處理之目的。因此，當科學研究符合公認之道德標準時，應允許資料主體僅就科學研究之特定範圍為同意之表示。資料主體應有機會僅就特定研究範圍或預期目的所允許範圍內之部分研究計畫表示同意。」個人資料保護委員會籌備處，歐盟個人資料保護規則前言部分（Recitals），<https://ws.pdpc.gov.tw/Download.ashx?u=L0ZTMDEvRmlsZVBhdGgvMy9yZWxmaWxILzI0LzExL2MzN2FkOWJhLTU5NjQ0NDhlMyliOGVhLWU2ZmJmZDk1MzU3OC5wZGY%3D&n=5q2Q55uf5YCL5Lq66LOH5paZ5L%2Bd6K236KaP5YmH5YmN6KiA6YOo5YiGKFJIY2l0YWxzKS5wZGY%3D>（最後瀏覽日：2025年8月4日）。

相反地，GDPR第33點基於「資料當事人應有機會僅就特定研究範圍或預期目的所允許範圍內之部分研究計畫表示同意」，不但要求必須要能夠一定程度地辨識科學研究之目的，並且在此所謂的符合標準，指的是「符合公認之道德標準」(recognised ethical standards)。GDPR的有權解釋機關EDPB就此處指出，在第33點所預設之情況下，資料控制人必須仔細評估資料當事人的權利、資料的敏感性、研究的性質和目的以及相關的道德標準。當研究目的無法完全加以特定時，資料控制人將被要求有更多之作為，包括儘可能透明以及其他依據GDPR第89條第1項所指之保障措施等，以確保資料當事人有效同意權的本質，亦即其資訊自主獲得保障¹⁷²。細繹前揭所指仔細評估之客體，則其正是透過評估之方法，以「不同科學研究領域相關的道德標準」而區分不同領域對公共利益之重要性為判準，來「預見未來對人民可能造成的影響」。

事實上，不惟僅有GDPR在解釋上是可以於進行科學研究前事先評估未來對人民可能造成的影響。在聯合國相關建議中，所需預先評估之事項更細緻化為對於：科學研究的目的、科學知識、尊重道德準則、所謂的效益為何、對資料處理的限制、資料當事人將面臨的風險、群體傷害的風險等。至於特別就基因資料而言，更應事先評估與資料當事人共享某些基因資料的血親將面臨的風險，以及發現非親子關係或其他意外家庭關係的風險等¹⁷³。再者，該建議更提出個資當事人必須在包括：(a)科學研究的性質、資料當事人可使用的備選辦法以及使用健康相關資料的任何相關條件，包括可能的再次連結識別和結果／發現的反饋；(b)萃取新形式的健康相關資料的手段和能力，以及未來可萃取資料的不確定性；(c)健康相關資料

¹⁷² EDPB, Document on response to the request from the European Commission for clarifications on the consistent application of the GDPR, focusing on health research, paras. 26-28 (Feb. 2, 2021).

¹⁷³ U.N., Privacy Rapporteur Report, *supra* note 169, section 15.4.

儲存的適用條件；(d)法律規定的權利和保障措施，特別是資料當事人拒絕同意為科學研究而處理資料的權利，和隨時撤回同意參與研究的權利；(e)研究的目的、方法、資金提供來源、任何可能的利益衝突、研究人員所屬的機構、預期效益和潛在風險，以及研究可能對受試者帶來的不適、研究後之相關規定和研究的任何其他相關問題；(f)將授權近用資料或可能出於其他目的合法尋求獲取近用之第三方身分，以及如何限制該等目的；(g)有計畫的跨國資料傳輸；(h)擬公開揭露的健康相關資料，以及任何預想在研究資料儲存庫中儲存的資料等事項中，從資料控制人處事先獲得盡可能準確的透明且可理解的資訊（“be provided with prior, transparent and comprehensible information that is as reasonably precise as possible”¹⁷⁴）。

復次，雖然GDPR對於當事人對符合標準之科學領域容許給與「廣泛同意」，以及對以科學研究為目的之個資處理應採取「廣泛解釋」之解釋並沒有錯，不過由於GDPR的前言部分本身並無拘束力，因此合併具拘束力的GDPR第9條關於處理特殊類別資料的嚴格條件觀察，EDPB則表示當在明確同意的基礎前提下處理特種資料時，如果要應用前言第33點之彈性方法，則需受到更嚴格的解釋，並需要受到高密度之審查¹⁷⁵。不惟如此，由於會員國法律中的相關條款也可能影響到該前揭關於「廣泛同意」的適用性，因此在運用前言第33點時，同時有必要考慮GDPR第9條第4項所允許的會員國國內法中其他關於與處理健康資料要件之條款¹⁷⁶。據此，本文認為前述對於應用個資於學術研究目的之行為，在以風險為本的GDPR當中，是可以事先以仔細評估方式¹⁷⁷區別不同領域公益重要

¹⁷⁴ *Id.* section 15.6.

¹⁷⁵ EDPB, Guidelines 05/2020 on consent under Regulation 2016/679, para. 157 (May 4, 2020).

¹⁷⁶ EDPB, *supra* note 172, at para. 30.

¹⁷⁷ 此處所指的事前仔細評估，應解為GDPR第35條所規範的個資風險評估（data protection impact assessment, DPIA）。

性，或預見未來對人民可能造成的影響，並以法律具體規範要求資料控制人與有關機關擔負該等責任的。

二、未來有關資料驅動科研之再利用法制

依本文分析既認為歐盟資料法制至今仍有其優點以及優勢，那麼在此基礎上，就臺灣未來有關資料驅動科學研究的資料再利用法制言，本文認為必須要關係機關能承擔信任擔保責任並有效監督管理個資應用行為，以及有更良好的公眾溝通作為。

（一）對於健康資料的再利用行為，需進行強而有效的全面性監管

從前揭關於美國與歐盟資料法制之分析，本文認為就資料權利、隱私權的保障而來之相對嚴謹的管制框架，以及政府有效的監督管理之間，非必為相互衝突矛盾之關係。本文主張，未來我國相關法制規範應當借鑑歐洲資料法制模式，而政府應在保障資料權利及個人與群體隱私權利之前提下，對健康資料之再利用與分享行為進行有效而強力的監督與管理措施。其原因如：(1)歐洲資料模式對科研友善，且在歐盟資料策略法制延伸的趨勢上，有利科研與資料分享；(2)歐洲資料法制模式開始特別考量公共利益以及個人基本權利與自由之衡平問題，對於衝突之發生能有效降低；以及(3)歐洲資料法制模式不但在國際上並未被破棄，且已儼然成為更加主流之模式等。另外，有效而強力的監督與管理措施除了可以使資料控制人與資料中介者有足夠之動機提升資料安全維護之程度外，亦可促渠等思考以科技方式保障個人資料權利及公共利益，並且使資料之應用因為信任之基礎而更加優化。

我國個資法由於原第47條至第50條之行政罰部分僅有數十萬臺幣之罰鍰，實務上主管機關在對個案進行處罰時，乃因依法可裁罰數額顯較所可能影響之損害與風險、應受責難之程度為低而飽受批

評¹⁷⁸。爰此，2023年5月於個資法修正條文第48條，修正非公務機關違反第27條第1項¹⁷⁹或未依第2項¹⁸⁰訂定個人資料檔案安全維護計畫或業務終止後個人資料處理方法之裁罰，即提高罰鍰數額（新臺幣2萬元以上200萬元以下罰鍰，並令其限期改正，屆期未改正者，按次處新臺幣15萬元以上1,500萬元以下罰鍰），並增訂違規情節重大者之罰則（新臺幣15萬元以上1,500萬元以下罰鍰，並令其限期改正，屆期未改正者，按次處罰）。另新增第1條之1，設置統籌性之獨立監督機關，擔任個資法主管機關，以「落實個人資料保護，促進個人資料之合理利用，並依憲法法庭一百十一年憲判字第十三號判決所示應建立個人資料保護獨立監督機制之意旨」，藉以「完足憲法第二十二條對人民資訊隱私權之保障」¹⁸¹。

然則，該次的極小幅度修法目的就主管機關對資料再利用與共享行為之監管效能來看，除關於個資保護委員會之必要設置外，重

178 余曉涵，iRent個資外洩40萬筆屆期未改善 公路總局開罰20萬，中央社，2023年2月9日，<https://www.cna.com.tw/news/ahel/202302090037.aspx>（最後瀏覽日：2023年3月24日）。

179 個人資料保護法第27條第1項：非公務機關保有個人資料檔案者，應採行適當之安全措施，防止個人資料被竊取、竄改、毀損、滅失或洩漏。

180 個人資料保護法第27條第2項：中央目的事業主管機關得指定非公務機關訂定個人資料檔案安全維護計畫或業務終止後個人資料處理方法。實務上我國相關的主管機關所指定之非公務機關類別，從指定內容來看，大約有兩種類型，其一為依據利用個資之不同行為作為指定標準，例如金融監督管理委員會指定非公務機關個人資料檔案安全維護辦法第2條所指定的金融控股公司、銀行業、證券業、期貨業、保險業、電子支付機構、其他經金融監督管理委員會公告之金融服務業，以及金管會主管之財團法人等；內政部指定合作及人民團體類非公務機關個人資料檔案安全維護管理辦法第3條所指定各級人民團體、合作社及儲蓄互助社、其他經中央主管機關公告指定者；內政部指定警政類、營建類；國家通訊傳播委員會指定者，經濟部指定者等。其二為依據規模作為指定標準，例如國家通訊傳播委員會指定非公務機關個人資料檔案安全維護辦法第2條第2款用戶數達三千戶以上之提供網際網路接取服務之設置未使用電信資源之公眾電信網路者，以及同條第5款訂戶數達三千戶以上之直播衛星廣播電視服務事業等。

181 立法院議案關係文書，院總第20號政府提案第10034077號，個人資料保護法第一條之一、第四十八條、第五十六條修正草案總說明，2023年4月13日。

點在於改善兩個非公務機關就資料安全維護措施之問題點：(1)原法之「處罰方式及管制效果不足，無法促使非公務機關投入成本、技術與人力，以遵守個人資料安全維護義務」；(2)「我國產業結構多數以中小企業為主，商業模式多樣，且不同業者違反安全維護義務行為之應受責難程度差距可能甚大，有必要賦予主管機關依違法情節行使裁罰權限」¹⁸²。而之所以聚焦於資料安全維護措施，其所企圖達成之目的並不在於有效地鼓勵與監管資料之再利用與共享行為，而是期待以減少強化資料安全維護方式降低個資外洩風險，以降低以個資之不法利用為手段之精準詐欺行為¹⁸³。綜言之，2023年之個資法修法雖在一定程度上強化了對於資料應用行為之監管，然重點毋寧在於提高對非公務機關就資料安全維護措施之強化動機，並未就資料安全維護措施之內容，尤其是資料再利用與共享行為之流通監管本身有新的要求。就此，本文認為個人資料合理利用相關之監管應至少在兩個面向上對於（健康）資料之再利用與共享行為予以強化：(1)應明確規範禁止再利用與共享之資料類型，以避免個人資料權利及公共利益之侵害；(2)應就得再利用與共享之健康資料予以有效監管，並禁止對於以假名化（健康）資料之再識別。

（二）建立信任擔保並不同於獲得公眾信任，然法制上必須導入信任擔保，以作為信任契機

在英國政府近來的健康資料再利用政策中，TRE雖為重要趨勢且在健康資料再利用與資料權利保障上有其作用，不過如果將TRE視為是英國，或是我國對於健康資料再利用實踐的唯一解方，則或許容有疑問：

¹⁸² 同前註。

¹⁸³ 關於該次修法中就資料安全與個資保護之問題分析，詳參：翁逸泓，個資安全與個資保護——非公務機關之個資安全維護計畫、措施與洩漏通報，當代法律，22期，頁6-12（2023年）；張志偉，個資保護與資料安全，當代法律，22期，頁13-20（2023年）。

1. 即便英國政府在GDPR計畫凍結前已宣示積極導入TRE，GDPR計畫仍然暫時喊停，因此從個案上看起來TRE並具不有足以獨立「回天」的條件。追根究底，除了在於或許可以用TRE處理相關的技術問題和隱私權利保護之複雜性問題外，正如英國醫師公會最主要的訴求，NHS Digital面臨的主要批評是其溝通策略無法建立民眾對於這個政策作為之信任關係：「資訊傳遞不明確且完全未能訂定廣泛而深遠的公眾參與計劃來與民眾溝通，便讓家庭醫生來傳達這些複雜的變化，而致完全不切實際的期望」（粗體字為本文強調）¹⁸⁴。

換言之，如果將無法尋得一個共通的TRE作為遁辭，而不斷地以話術曲解誇大健康資料再利用於科學研究的公益性，又或是僅只依靠技術即可絕對保證資料安全以及資料權利，則可能被視為是忘卻了英國在care.data以降的深刻經驗：未能獲得公眾信任的大規模健康資料再利用政策，即便舉著科學研究之「特別重大公共利益」大纛，仍可能迎來失敗。換言之，該計畫的失敗經驗除了顯示清楚溝通的重要性，重點毋寧在於反覆地表明近用資料的明確規則、近用的透明度、對隱私風險的良好緩解、以及對新應用的社會參與認可等，對於與社會大眾溝通來說，均極其重要¹⁸⁵。

2. 雖然得到公眾信任極為重要，然而，諸如TRE的資訊安全環境作為「信任擔保」的概念與「建立信任」的本身，似有扞格：從論理的角度以觀，「信任」（trust）本身應與「值得信任」（trustworthy）的概念加以區辨，前者乃是當事的行為人

¹⁸⁴ British Medical Association Media Team, *BMA Calls for Delay in Roll-Out of Patient Data Sharing Programme*, BRIT. MED. ASS'N (June 4, 2021), <https://www.bma.org.uk/bma-media-centre/bma-calls-for-delay-in-roll-out-of-patient-data-sharing-programme>.

¹⁸⁵ Goldacre & Morley, *supra* note 108, at 154-55.

對他人的主觀態度；而後者則是信任基礎之特質。由於前者涉及當事人本身的期待，但是這種期待除了面臨信任的「期待」無法實現的挫折風險以外，也可能同時因為期待的結果未能實現，而使該等「信任本身」受到挫折（信任遭到背叛），產生雙重的脆弱性¹⁸⁶。然而，「信任」與「值得信任」之間通常呈現相反的矛盾趨勢。細言之，當行為人對於被信任者擁有的「值得信任」支撐證據越多，表示對於被信任者「值得信任」的程度越高。但是，當行為人決定可以「信任」對方時，需要的「值得信任」支撐證據卻要更多、更穩固，以作為信任的擔保，這卻同時意味著原本的「信任」並不充足，所以才會需要更多「值得信任」的支撐證據來強化信任。因此，有論者認為進一步的支撐證據蒐集似乎會破壞而不是增強信任¹⁸⁷。

檢視TRE的制度設計，包括確認資料再利用目的、保障近用權利、透明原則以及問責原則等，都是作為使得健康資料再利用行為「值得信任」的強化資料安全擔保，也就是以「不信任」研究者等資料控制人與利用人，而作為「值得信任」支撐證據，使更多個資當事人願意其健康資料為了科學研究之目的而為再利用¹⁸⁸。基於此，如果依照前揭的這個脈絡，則TRE反而會因為消除（或降低）了「信任」這個概念可能令人期待落空或遭到背叛的方式；亦即，TRE雖然透過強化資料安全環境的建置，減少信任本身的脆弱性並使得資料濫用行為難度增加，但是其本身並沒有藉此提高資料當事人對於健康資料再利用行為的信任度，從而使「信任」變得沒有

186 Graham et al., *supra* note 114, at 670.

187 *Id.* at 671.

188 *Id.*

必要¹⁸⁹。基於此，論者認為所謂的TRE，應當正名為「安全研究環境」(secure research environments)¹⁹⁰。

綜上，本文認為TRE這種建立資料安全信任擔保的制度，所獲得的結果僅得到對於信任的較佳支撐證據，而令再利用健康資料於研究「值得信任」，但最終卻不一定能夠獲得公眾信任。不過，如果依循這個論理邏輯，TRE本身並無法建立或強化「公眾信任」(public trust)，甚至可能有論者認為建立「公眾信任」所關懷的是被信任，而不是值得信任的事實，因此雖然值得信任通常是讓別人信任的有效方式，但情況並非必定如此¹⁹¹。然則，由於在獲得信任擔保而使資料共享成為值得信任的情況下，對共享健康資料的期望有較大機會可能發生轉變，也因此公眾對其健康資料願意接受的脆弱性程度可能會發生變化。故此，TRE這種資料安全環境強化信任擔保的機制，在對於健康資料再利用於科學研究的資料治理面向上，仍有其不容忽視的重要性，只不過這個擔保機制，仍然需要透過民眾參與治理等公眾溝通方式，獲得公共信任。

回到臺灣實務，我國政府順應國際資訊安全技術趨勢中與TRE異曲而同工的零信任架構(zero trust architecture, ZTA)¹⁹²概念，亦

189 *Id.* at 671-72.

190 *Id.* at 672.

191 論者指出例如當事人可能正確地認為某相對人值得信任，但選擇不信任他們，原因是當事人並不想給相對人帶來負擔。Onora O'Neill, *Linking Trust to Trustworthiness*, 26 INT'L J. PHIL. STUD. 293, 293-300 (2018), cited from *id.* at 672.

192 零信任架構(zero trust architecture, ZTA)是一種資訊安全框架，其主要理念是不再假設任何人或裝置是可信的，而是要求對所有資源和裝置的近用都進行身分驗證、授權和評估，以確保安全性。在傳統的網路安全架構中，通常假設在企業或網路安全架構利用者內部的使用者和資源是可信的，而來自外部網路的使用者和資源是不可信的。然而，隨著相關單位越來越依賴雲端技術、移動裝置和遠端近用，傳統的安全模型已經變得無法應對現代安全挑戰。相較之下，零信任架構認為每個裝置和資源都可能被入侵，所以必須對所有資源和裝置的近用進行評估和授權，而不僅僅是假設某些內部的裝置和資源是可信的，因此在ZTA下，每個使用者、裝置、應用程式和資源都必須進行身分驗證、多重因素驗證、資源和應用程式控制、行為分析、威脅偵測和

已提出零信任網路（zero trust network, ZTN）機制政策，作為保護資料與應用存取的身分辨識機制¹⁹³。無論是TRE或是ZTN/ZTA，都是作為保護資料的一種安全環境建置，目的在於作為信任擔保而提高值得信任之可能。然則，除了在資訊安全技術本身的導入，本文認為在法制環境上也應該要進行這個概念的安置。

或許有不同意見者認為資安技術與法律制度是不同之事而認為混為一談乃屬無稽。然則，在Goldacre Review當中可以發現TRE的要素之一即是透過管制體系設計的改善，而資訊的治理同時也應考量患者與公共參與。另方面在資料治理框架下的資料再利用行為，NHS England除了有內部資料保護官的獨立監督機制作為資料近用的組織保障外，基於對於資料控制人的NHS本身內部可存取健康資料庫的「不信任」，亦搭配外部獨立監督機關IC以及NDG作為信任擔保而嚴格監督去識別化措施下的身分辨識與存取以建立值得信任之可能，乃與ZTN/ZTA內涵特徵一致。本文認為尤其是在我國已發生控管健保資料庫的健保署內部本身疑似人員外洩個資事件¹⁹⁴，顯見內部監督機制有其不穩定性格，而須以零信任之心態對所有資料近用進行評估和監督，而不僅僅是假設某些內部的組織機制是可信的。

自動應對和授權，並且必須持續地進行評估和監控。美國聯邦政府便在2022年公告導入於政府架構中。*Office of Management and Budget Releases Federal Strategy to Move the U.S. Government Towards a Zero Trust Architecture*, THE WHITE HOUSE (Jan. 26, 2022), <https://bidenwhitehouse.archives.gov/omb/briefing-room/2022/01/26/office-of-management-and-budget-releases-federal-strategy-to-move-the-u-s-government-towards-a-zero-trust-architecture/>.

¹⁹³ 以零信任網路為例，數位發展部資通安全署於國家資通安全發展方案（110年至113年）導入ZTN，www-api.moda.gov.tw/File/Get/acs/zh-tw/x9U2Gtwj3y8EaXF（最後瀏覽日：2025年9月5日）；另外對於零信任架構，可參金融監督管理委員會，金融業導入零信任架構參考指引，<https://www.fsc.gov.tw/uploaddowndoc?file=news/202407181537330.pdf&filedisplay=%E9%87%91%E8%9E%8D%E9%9B%B6%E4%BF%A1%E4%BB%BB%E6%9E%B6%E6%A7%8B%E5%8F%83%E8%80%83%E6%8C%87%E5%BC%95.pdf&flag=doc>（最後瀏覽日：2025年9月5日）。

¹⁹⁴ 陳婕翎，健保署員工涉洩漏警調人員個資 暫調離原職限縮查閱權限，中央社，2023年1月10日，<https://www.cna.com.tw/news/asoc/202301100056.aspx>（最後瀏覽日：2023年3月24日）。

(三) 健康資料再利用之規範設計

既然本文認為TRE包括「確認資料再利用目的、保障近用權利、透明原則以及問責原則」所獲得者，或許僅只是得到對於信任的較佳支撐證據，因此或許即便個資法修法之結果能有效地回應大法官們在憲法法庭111年憲判字第13號判決關於當事人同意是否應為健保資料二次利用之必要要求、個資去識別程度之要求、當事人請求停止利用權之設計，應否有回饋機制的設計，以及對個資之蒐集、處理與利用行為的監督保護機制應如何設計等問題，仍然可以嘗試較全面的資料治理法制設計，以獲得更優化之信任擔保。本文認為除了於英國相關政策仍在建構與資料保護法修正之草案階段，另外包括DGA以及EHDS，基於其核心本旨在於促使研究人員、創新者和政策制定者有可能以可信任且安全的方式利用該等電子健康資料，同時保護隱私¹⁹⁵，可為借鏡。本文認為可能的本土法制設計至少應就以下幾個面向加以考量：

1. 健康資料可被處理以供二次利用之要件

在GDPR第20條第1項第a款當中規範有資料可攜權（right to data portability），個資當事人僅適用於基於同意或契約處理的資料，因此在解釋上排除依其他法律依據處理的資料，例如為了履行公共利益或控制者行使官方權力的任務時，而處理個資之情狀。再依同條第2項，自然人僅在技術上可行的情況下，才有權將個人資料直接從一個個資控制者傳輸到另一個個資控制者。然而，GDPR並未強制要求使這種直接傳輸在技術上可行，因此實際上可能限制了資料可攜性之實用性而降低其對自然人提供高品質、安全和高效率的醫療服務¹⁹⁶。

¹⁹⁵ European Health Data Space proposal, Explanatory Memorandum & recital 61.

¹⁹⁶ European Health Data Space proposal recital 11; European Health Data Space recitals 14-15.

但是，在EHDS中關於政府資料再利用之基本精神之一，乃是自然人應進一步被賦予可以交換和提供個人電子健康資料予其所選擇的醫療專業人員之**控制權利**。基於此，或許我國除參考EHDS提案第33條規範當自然人之同意係由各國法律所要求取得時，健康資料近用機構應基於EHDS規定之義務，提供電子健康資料之近用外¹⁹⁷，健康資料近用機構亦得提供其他種類的電子健康資料之近用途徑，例如經會員國內國法律所授權者，或是基於與當事人自願合作之資料持有者所得之近用¹⁹⁸，並且，近用之行為需採取一切必要措施來保護智慧財產權和營業祕密等第三人權益¹⁹⁹。

在健康資料再利用禁止方面，EHDS提案第35條則規定包括：依據自然人的電子健康資料，做出對自然人有害的決策，且該等決策係產生法律效力或具相同效果以嚴重影響該自然人；做出使相關自然人或一群自然人，遭排除其等獲取保險契約利益之決策或是影響其保費；向健康專業人士、健康領域之團體或自然人進行廣告、行銷活動；向未經許可之第三方提供電子健康資料，或使資料對第三方成為可近用；以及開發可能會傷害個人或社會的產品或服務，包含但不限於非法藥物、酒精飲料、菸草產品，或其他以違反公共秩序或道德，以設計或改裝之產品或服務等。

綜上，本文建議之健康資料可提供再利用要件，在積極條件上，除健康資料當事人同意及法律所規定者外，可考量適度容納經法律授權或基於與當事人自願合作，且在其近用資料行為具必要措施，以保護該等資料上之第三人權利之資料持有者。

197 European Health Data Space proposal art. 33(5). 須注意者，這個概念在EDPB及EDPS (European Data Protection Supervisor) 對EHDS提案之共同意見認為本項所指的「同意要求」並不明確，而因此可能讓健康資料近用組織得無視會員國法律規定之相關要求，在最後公布的EHDS版本中即將此部分刪除。

198 European Health Data Space proposal art. 33(8); European Health Data Space art. 51(2)-(4).

199 European Health Data Space proposal art. 33(4); European Health Data Space art. 52.

再就消極條件言，本文認為法律應先明確規範不得再為利用之資料類型，則該等健康資料就應該不是不得再利用之個資類型（例如EHDS提案第35條所規定者），並應明定禁止故意對於已去識別化之資料再為識別之行為，及該行為之法律效果；末以健康資料再利用之監督論，亦應注意令權責單位能有效且負責地予以監督管理。

2. 假名化與禁止再識別

在去識別化問題上，本文於前節提出應揚棄對「去識別化措施」本身之糾纏，而將個資視為仍可識別特定個人之個資進行處理。這個概念也能在EHDS提案尋得：EHDS提案在前言第64點指出，某些類別的電子健康資料即便是處於匿名化（anonymised）格式狀態而不屬於個人資料，仍然可能仍具特別敏感性²⁰⁰。例如在罕見疾病的情狀中，因為病例數有限，降低了完全聚合已發表的資料以保護自然人隱私的可能性，所以即使在使用最先進的匿名化技術的情況下，仍然存在導致已經被重新識別或可得被識別的一定風險²⁰¹，而超出了合理匿名可能使用的手段。此際，除針對重新識別風險的保護措施，應考量以下幾點：

- (a) 根據不同資料類別或不同匿名化或聚合技術的特殊性，應理解其風險差異；
- (b) 基於國際上相關去識別標準不一，因此DGA²⁰²以及EHDS提案均要求會員國應制定適用於將該等資料轉移到第三國的特殊條件之規範；
- (c) 對自然人重新識別的風險的實現將帶來重大隱憂，可能會危及在資料治理中規定的資料再利用政策。

200 此與DGA第5條第13項之觀點一致。

201 See also MARK ELLIOT ET AL., THE ANONYMISATION DECISION-MAKING FRAMEWORK 9-10 (2d ed. 2020).

202 DGA art. 5(13).

基於以上問題，EHDS提案在第44條規定了健康資料近用機構應在資料利用者目的可達成之前提下，以匿名化格式提供電子健康資料。同條並明定其他去識別化之規定，包括當資料利用者之目的無法以匿名化資料方式達成時，健康資料近用機構應綜合考量資料利用者提供的資訊，改以假名化方式提供電子健康資料的近用。再者，可回推出原始資料的必要資料，須僅限於健康資料近用機構內部流通。最後，資料利用者不得對其所獲以假名化格式之電子健康資料進行再識別，而資料利用者未充分遵從健康資料近用機構為確保假名化所要求之措施時，應受適當懲罰²⁰³。

準此，本文認為或許可揚棄過度執著於在實務上難以擔保假名化措施能有效達成原本設定目標之問題，重點毋寧應放在有利資料隱私權利之保障的重新識別防免措施²⁰⁴，以及禁止故意再識別之保護規範：這就像是雖然鎖頭必須合理／按照比例地依照當時技術予以更新代換，但是永遠都不能擔保會有對應的開鎖方法，而以法律規範之方式，以國家強制力為後盾，禁止有人以故意的方式試圖破解鎖頭。

3. 信任的形塑：組織擔保機制

無論是歐盟或是英國法制上對於健康資料再利用行為之核心價值均聚焦在信任關係之建立，本文認為在資料法制上與臺灣現行框架最大差異點，乃在於對於主管機關資料治理責任之強化要求。以EHDS提案為例，即要求會員國應特別指定一個負責實施與執行數位健康資料利用之監理機關（digital health authority）²⁰⁵，以及專責

203 事實上在英國的2018年資料保護法中，第171條與第172條早就規定有「將去識別化個資重新識別罪」。

204 嘗試再識別個資之行為多有串接其他個資之態樣，因此在歸類上本文將其歸類於妨害個人資料權利。

205 European Health Data Space proposal art. 10(1); European Health Data Space art. 19(1).

健康資料再利用之單位（health data access body）²⁰⁶。並且，EHDS提案也特別就健康個資保護面向上規定負責監督GDPR施行的監督機關，也應負責監督健康資料利用係依GDPR第6章至第8章的相關規定為之。該等個資保護監督機關和EHDS提案第10條所指數位健康資料利用之監理機關，在各自權限範圍內，應於適當情況下相互合作²⁰⁷。尤其是在救濟程序部分，EHDS提案第11條規定自然人及法人應有權向數位健康資料利用之監理機關以個人或團體方式申訴，且如申訴內容有包含GDPR之個資權利保護，則數位健康資料利用之監理機關應通知個資保護之監督機關。

須注意者，就健康資料再利用之監理機關言，EDHS指的是應特別指定一個負責對該資料利用行為之主管機關，雖然細觀該提案內容並無特別說明是否係「另設」監理機關，而係指定（designate）一個數位健康資料之監理機關，但是揆諸EDHS提案第10條第2項第n款，該數位健康資料監理機關應與其他包括電子身分認證與信賴服務規則²⁰⁸、GDPR、網路與資訊系統安全指令²⁰⁹以及負責網路安全、電子身分識別之機關、歐洲人工智慧委員會（European Artificial Intelligence Board）、醫療器材協調群組（Medical Device Coordination Group）、歐洲資料創新委員會（European Data Innovation Board）

206 European Health Data Space proposal art. 36(1); European Health Data Space art. 55.

207 European Health Data Space proposal art. 3(11); European Health Data Space art. 57(2)(a).

208 Regulation (EU) No 910/2014 of the European Parliament and of the Council of 23 July 2014 on electronic identification and trust services for electronic transactions in the internal market and repealing Directive 1999/93/EC, 2014 O.J. (L 257) 73.

209 Directive (EU) 2016/1148 of the European Parliament and of the Council of 6 July 2016 concerning measures for a high common level of security of network and information systems across the Union, 2016 O.J. (L 194) 1. 該指令被稱為NIS 1指令，其後該指令以NIS 2指令替代，即Directive (EU) 2022/2555 of the European Parliament and of the Council of 14 December 2022 on measures for a high common level of cybersecurity across the Union, amending Regulation (EU) No 910/2014 and Directive (EU) 2018/1972, and repealing Directive (EU) 2016/1148 (NIS 2 Directive) (Text with EEA relevance), 2022 O. J. (L 333) 80.

與資料法（Data Act）監理機關等其他相關機關合作來看，基於一般個資領域與特別個資領域的監管依據與面向不同言，本文認為我國或可考量在個資保護委員會外，另行「指定」（而非必為創設）一機關或組織處理該事務。

又，細觀數位健康資料利用監理機關之職權，除在歐盟層級就各會員國間業務之合作交流，並制定歐洲電子健康紀錄交換格式、紀錄系統、歐盟健康應用程序資料庫規格，以及制定歐洲共同電子健康資料規格，以解決資料流通上之相互操作性、安全性或基本權利方面的問題外，對於信賴關係在建構上緊密連結者，乃以資訊受託人模式為本，令其依EHDS提案第28條以執行市場監督活動²¹⁰、糾正後之改善措施²¹¹以及撰寫年度報告²¹²等，確保避免任何利益衝突。

除規範設計外，健康資料再利用的對應機制或許也應考量，以利增幅當事人對再利用行為機制之信任：

- (1)基於當事人資料權利之強化控制，可適當考量法律授權及當事人自願合作之選項，除了法律規範方式以外，亦可搭配技術性之線上動態同意機制，使個資當事人之事前、事中，與事後等對於個資利用行為之整體控制權能較佳地反應。惟為與其他公共利益與個人權利衡平，除採取資料安全與資訊安全之保護措施外，仍應規範禁止或限制利用之事項。
- (2)健康資料近用機構可以整合性（one-stop）公開資訊平台之方式，提供相對即時之健康資料再利用以及共享等行為相關資訊，包括例如整體健康資料再利用與共享狀況、回饋情況，以及提供公共利益利用相關資訊等²¹³。

210 European Health Data Space proposal art. 10(2)(i).

211 European Health Data Space proposal art. 10(2)(l).

212 European Health Data Space proposal art. 10(2)(o).

213 European Health Data Space proposal art. 37; European Health Data Space art. 57.

- (3)應有組織擔保機制以強化當事人與資料利用人間之信任關係。監督機關應監督資料之中介服務提供者係採取對資料當事人最佳利益之方式為資料之再利用，除與主管機關及個資保護獨立專責機關間相互合作外，亦應保障資料當事人之救濟權利。

伍、結論

首先，基於於歐盟資料法制能夠建立與維持政府與民眾間的信任關係，因此仍應繼續安置於我國相關法制。歐盟資料法制具有外溢至其法律管轄區域外之效果，甚至成為國際標準的布魯塞爾效應（Brussels effect）²¹⁴，不過本文認為臺灣之所以不應棄守歐盟資料法制模式的原因卻不僅僅是因為該資料法制模式的國際實務影響力²¹⁵，本文更是在論理上提出如果將歐盟法制視作是不利於科研發展的立法模式，或許是錯誤的。美國的資料法制如HIPAA、CCPA等，在健康資料加值應用與發展上，因為履行對個資當事人知情權之責任成本較高，並且對為個資特定目的外而因科學研究利用個資之行為，可能並不實質友善，因此未必絕對地有利於以健康資料驅動之科學研究。相反地，由於GDPR在例外允准利用的適用範圍上與CCPA/CPRA之規定相異，判斷標準乃是所涉研究實體之本質的緣故，或許歐盟資料保護法制相對於美國資料法制模式言，反倒有利於科學研究。

214 ANU BRADFORD, THE BRUSSELS EFFECT: HOW THE EUROPEAN UNION RULES THE WORLD 131-69 (2020).

215 除歐盟外，其他國家如鄰近我國之日本、韓國等均修改法制而已獲得歐盟GDPR之適足性認定，加州資料法制亦向歐盟資料法制靠攏。並且，觀諸聯合國健康相關資料之保護與利用（The Protection and Use of Health-Related Data）建議，其規範亦明顯以歐盟資料模式為本。

不過即便如是，歐盟的資料法制仍舊難以擺脫複雜體系之問題。然則，就算法律體系因為需要與各會員國法律相互配合銜接，並需要保持更即時的動態化而愈趨複雜，但是因為歐盟資料法制將資料當事人對健康研究的參與，理解為與研究者基於信任關係的研究夥伴。準此，歐盟的健康資料法制，便以貌似複雜，但實質上友善的管制方式，在綿密的體系架構中，處理在健康資料研究的權利平衡問題。

再就深受歐盟個資法制模式影響，卻已然因為脫歐而想要有新方向資料法制的英國來看，其健康資料再利用於科學研究的實際經驗卻是跌跌撞撞。雖然在英國的*Source Informatics*案中，政府方獲得勝訴判決，但是這個顯然忽略該等程度的「匿名化」仍可能有涉資訊自主與對於個資當事人資料權利所生影響的判決，毫無意外地引起相當大的爭論，並且由於該時並未導入歐盟資料法制，因此對於該等去識別化的個人資料在資料法制上，並未有所評價。此後於落實歐盟資料法制後，英國則接續迎來包括care.data與GDPR計畫的兩次失敗經驗。究其癥結，問題點主要落在政府與民眾間尤其就資訊隱私和安全性與資料利用透明度和可控性等議題，未建立足夠的「信任」關係。

準此，本文基於論理，認為我國仍應維持歐盟資料法制之基礎。

其次，英國新進資料政策與法制，仍在一定程度上受歐盟資料法制影響。由於英國政府期待未來能在資料法制上有所「轉向」而能更積極地應用健康資料於科學研究甚至產業運作，因此以Goldacre Review嘗試提出TRE作為解方，認為法制規範與政策架構上要塑造出所謂保護隱私的「可證明的、可信的」方法，前提之一是資料利用人和管理該等分享行為的法規是值得信任的（trustworthy）。不過，從相關的法制變革以及相關政策與執行說明文件來看，因為新政策與新法制將TRE之信任擔保責任作為健康資

料再利用與共享的前提，並嘗試將健康資料再利用與共享條件清楚地規範，以克服告知後同意的實踐問題，因此本文認為與其將其新進的資料應用法制解釋為「轉向」，毋寧應解為將信任關係安置於包括（健康）資料再利用行為等資料治理的模式當中。

回到我國健保資料庫案來看，健保資料庫案中憲法法庭在主文一指出，個人資料保護法第6條第1項但書第4款的健康資料目的外再利用於科學研究之相關規定與法律明確性原則、比例原則尚屬無違，因此並不牴觸憲法第22條保障人民資訊隱私權之意旨。本文認為此間或許仍有以本文前揭比較法與論證為基礎而探究之餘地。

本文認為對於資訊隱私之概念應採歐盟資料法制之脈絡解釋，故不應該採取限縮內涵的解釋方法，並因此建議揚棄對於「去識別化措施」概念本身的糾纏。其次，我國的個資法雖然在主要架構上移植的是歐盟個資保護模式，但是所承繼的版本卻是基於歐盟個資保護指令（Directive 95/46/EC），而不是在2016年已然更新以風險為本作為核心思維的GDPR，因此現行法律僅透過傳統上區分不同學術研究和不同公益重要性的方式來衡平個人資料權利與公共利益，並不足以真正地反映人民個資權利可能受到的風險，也難以符合比例原則的實質判斷。

最後，本文此前論述既認為歐盟資料法制至今仍有其優點以及優勢，那麼在此基礎上，就臺灣未來有關資料驅動科學研究的資料再利用與資料共享等相關的資料治理法制言，本文認為必須要關係機關、資料控制人、資料利用人以及資料中介者等對於資料有高度控制權與控制可能者，能承擔信任擔保責任並有效監督管理個資應用行為，以及有更良好的公眾溝通作為。

參考文獻

1. 中文部分

- 何之行（2022），英國生醫健康資料之整合應用與資料治理規範，
月旦法學雜誌，331期，頁9-23。
- 吳全峰、許慧瑩（2018），健保資料目的外利用之法律爭議——從
去識別化作業工具談起，月旦法學雜誌，272期，頁45-62。
- 李寧修（2020），個人資料合理利用模式之探析：以健康資料之學
術研究為例，臺大法學論叢，49卷1期，頁1-50。
- 胡林（2018），史上最嚴個資法GDPR上路，能力雜誌，750期，頁
17-19。
- 翁逸泓（2019），開放全民電子健康資料加值應用之個資保護問
題——以英國經驗為例，月旦法學雜誌，285期，頁144-173。
- （2022），資料治理法制：歐盟模式之啟發，東海大學法學
研究，64期，頁55-116。
- （2022），數位通訊傳播管制與個資保護：APPLE與
FACEBOOK的歐洲隱私權戰役啟發，東吳法律學報，33卷4
期，頁35-78。
- （2023），個資安全與個資保護——非公務機關之個資安全
維護計畫、措施與洩漏通報，當代法律，22期，頁6-12。
- 翁逸泓、李寧修（計畫主持人）（2020），歐盟國家個人資料保護法
制因應GDPR施行之調適——以德國與英國為例，委託研究計
畫結案報告（GRB系統編號：PG10805-0109），臺北：國家發
展委員會。
- 張志偉（2023），個資保護與資料安全，當代法律，22期，頁13-
20。
- 張陳弘（2022），美國加州消費者隱私保護法制之最新發展與比較

法啟示，當代法律，6期，頁24-39。

許明暉（2020），精準醫療年代的健康資料治理，國土及公共治理季刊，8卷3期，頁76-81。

劉定基（2018），試評「數位通訊傳播法」草案，收於：彭芸、葉志良編，匯流、治理、通傳會論文集，頁283-309，新北：風雲論壇。

劉靜怡（2020），人工智慧時代的法學研究路徑初探，收於：李建良編，法律思維與制度的智慧轉型，頁93-136，臺北：元照。

2. 外文部分

Adams, Carolyn, Judy Allen, and Felicity Flack. 2022. *Sharing Linked Data for Health Research: Towards Better Decision Making*. Cambridge: Cambridge University Press.

Balkin, Jack M. 2016. Information Fiduciaries and the First Amendment. *University of California Davis Law Review* 49:1183-1234.

———. 2020. The Fiduciary Model of Privacy. *Harvard Law Review Forum* 134:11-33.

Bankava, Agnese, Arnis Buka, Signe Mežinska, and Juris Barzdins. 2020. The Effect of GDPR on Secondary Use of Data Concerning Health in Research: Latvian Case in the European Context. Available at https://www.apgads.lu.lv/fileadmin/user_upload/lu_portal/apgads/PDF/Juridiskas-konferences/ISCFLUL-7-2019/iscflul.7.2-16_Bankava_Buka_Mezinska_Barzdins.pdf.

Beyleveld, Deryck. 2006. Conceptualising Privacy in Relation to Medical Research Values. Pp. 151-164 in *First Do No Harm: Law, Ethics and Healthcare*, edited by Sheila A. M. McLean. Farnham: Ashgate.

Bidault, Mylène. 2021. Considering the Right to Enjoy the Benefits of Scientific Progress and Its Applications as a Cultural Right: A

- Change in Perspective. Pp. 140-149 in *The Right to Science: Then and Now*, edited by Helle Porsdam and Sebastian Porsdam Mann. Cambridge: Cambridge University Press.
- Bradford, Anu. 2020. *The Brussels Effect: How the European Union Rules the World*. New York, NY: Oxford University Press.
- . 2023. *Digital Empires: The Global Battle to Regulate Technology*. New York, NY: Oxford University Press.
- Comandè, Giovanni, and Giulia Schneider. 2022. Differential Data Protection Regimes in Data-Driven Research: Why the GDPR is More Research-Friendly Than You Think. *German Law Journal* 23:559-596.
- Curry, Edward, Simon Scerri, and Tuomo Tuikka. 2022. Data Spaces: Design, Deployment, and Future Directions. Pp. 1-17 in *Data Spaces: Design, Deployment and Future Directions*, edited by Edward Curry, Simon Scerri and Tuomo Tuikka. Cham: Springer.
- Dumortier, Jos, and Mahault Piéchaud Boura. 2020. European-wide Big Health Data Analytics under the GDPR. Pp. 56-70 in *Health Data Privacy under the GDPR: Big Data Challenges and Regulatory Responses*, edited by Maria Tzanou. New York, NY: Routledge.
- Duquenoy, Penny, Nermeen M. Mekawie, and Mark Springett. 2013. Patients, Trust and Ethics in Information Privacy in eHealth. Pp. 275-295 in *eHealth: Legal, Ethical and Governance Challenges*, edited by Carlisle George, Diane Whitehouse and Penny Duquenoy. London: Springer.
- Elliot, Mark, Elaine Mackey, and Kieron O'Hara. 2020. *The Anonymisation Decision-Making Framework*. 2d ed. Manchester: UK Anonymisation Network.
- Goldacre, Ben, and Jessica Morley. 2022. Better, Broader, Safer: Using Health Data for Research and Analysis. In *Department of Health*

- and Social Care*, <https://www.gov.uk/government/publications/better-broader-safer-using-health-data-for-research-and-analysis>.
- Graham, Mackenzie, Richard Milne, Paige Fitzsimmons, and Mark Sheehan. 2023. Trust and the Goldacre Review: Why Trusted Research Environments Are Not about Trust. *Journal of Medical Ethics* 49:670-673.
- Guagnin, Daniel, Leon Hempl, and Carla Ilten. 2011. Privacy Practices and the Claim for Accountability. Pp. 99-114 in *Towards Responsible Research and Innovation in the Information and Communication Technologies and Security Technologies Fields*, edited by René von Schomberg. Luxembourg: Publications Office of the European Union.
- Hall, Joseph L., and Deven McGraw. 2014. For Telehealth to Succeed, Privacy and Security Risks Must Be Identified and Addressed. *Health Affairs* 33:216-221.
- Harris, John. 2005. Scientific Research Is a Moral Duty. *Journal of Medical Ethics* 31:242-248.
- Hartzog, Woodrow, and Neil M. Richards. 2020. Privacy's Constitutional Moment and the Limits of Data Protection. *Boston College Law Review* 61:1687-1761.
- Koeninger, Kelly, and John Conley. 2020. International Health Data: How HIPAA Interacts with the EU GDPR. *Health Law Connections* 24(1):40-43.
- Koops, Bert-Jaap, Bryce Clayton Newell, Tjerk Timan, Ivan Škorvánek, Tomislav Chokrevski, and Maša Galič. 2017. A Typology of Privacy. *University of Pennsylvania Journal of International Law* 38:483-575.
- Laurie, Graeme. 2021. Private and Public Dimensions of Health Research Regulation: Introduction. Pp. 227-228 in *The Cambridge*

- Handbook of Health Research Regulation*, edited by Graeme Laurie, Edward Dove, Agomoni Ganguli-Mitra, Catriona McMillan, Emily Postan, Nayha Sethi and Annie Sorbie. Cambridge: Cambridge University Press.
- Porsdam, Helle, and Sebastian Porsdam Mann. 2021. Introduction. Pp. 1-14 in *The Right to Science: Then and Now*, edited by Helle Porsdam and Sebastian Porsdam Mann. Cambridge: Cambridge University Press.
- Postan, Emily. 2021. Changing Identities in Disclosure of Research Findings. Pp. 229-238 in *The Cambridge Handbook of Health Research Regulation*, edited by Graeme Laurie, Edward Dove, Agomoni Ganguli-Mitra, Catriona McMillan, Emily Postan, Nayha Sethi, and Annie Sorbie. Cambridge: Cambridge University Press.
- Quinn, Brendan. 2021. *Data Protection Implementation Guide: A Legal, Risk and Technology Framework for the GDPR*. The Netherlands: Wolters Kluwer.
- Rashbaum, Kenneth N. 2022. The Business Opportunities of GDPR. Pp. 125-143 in *The GDPR Challenge: Privacy, Technology, and Compliance in an Age of Accelerating Change*, edited by Amie Taal. Boca Raton, FL: CRC Press.
- Romano, Cesare P. R. 2021. The Origins of the Right to Science: The American Declaration on the Rights and Duties of Man. Pp. 33-53 in *The Right to Science: Then and Now*, edited by Helle Porsdam and Sebastian Porsdam Mann. Cambridge: Cambridge University Press.
- Saks, Michael J., Adela Grando, Chase Millea, and Anita Murcko. 2020. Advancing the Use of HIE Data for Research. *Arizona State Law Journal* 52:145-189.
- Schrey, Joachim. 2018. General Conditions for Data Processing in

- Companies under the GDPR. Pp. 105-194 in *New European General Data Protection Regulation: A Practitioner's Guide*, edited by Daniel Rücker and Tobias Kugler. London: Bloomsbury.
- Solove, Daniel J. 2006. A Taxonomy of Privacy. *University of Pennsylvania Law Review* 154:477-560.
- Svanberg, Christian Wiese. 2020. Article 89 Safeguards and Derogations Relating to Processing for Archiving Purposes in the Public Interest, Scientific or Historical Research Purposes or Statistical Purposes. Pp. 1240-1251 in *The EU General Data Protection Regulation (GDPR): A Commentary*, edited by Christopher Kuner, Lee A. Bygrave, Christopher Docksey and Laura Drechsler. New York, NY: Oxford University Press.
- Taylor, Linnet, Luciano Floridi, and Bart van der Sloot. 2017. Introduction: A New Perspective on Privacy. Pp. 1-12 in *Group Privacy: New Challenges of Data Technologies*, edited by Linnet Taylor, Luciano Floridi and Bart van der Sloot. Cham: Springer.
- Taylor, Mark. 2015. *R v Department of Health, ex parte Source Informatics Ltd [1999]*. Pp. 175-192 in *Landmark Cases in Medical Law*, edited by Jonathan Herring and Jesse Wall. London: Bloomsbury.
- Taylor, Mark, and Tess Whitton. 2021. Health Research and Privacy through the Lens of Public Interest: A Monocle for the Myopic?. Pp. 239-247 in *The Cambridge Handbook of Health Research Regulation*, edited by Graeme Laurie, Edward Dove, Agomoni Ganguli-Mitra, Catriona McMillan, Emily Postan, Nayha Sethi and Annie Sorbie. Cambridge: Cambridge University Press.
- Vukovic, Jakov, Damir Ivankovic, Claudia Habl, and Jelena Dimnjakovic. 2022. Enablers and Barriers to the Secondary Use of Health Data in Europe: General Data Protection Regulation

Perspective. *Archives of Public Health* 80(115):1-9.

Waldman, Ari Ezra. 2015. Privacy as Trust: Sharing Personal Information in a Networked World. *University of Miami Law Review* 69:559-630.

Werbach, Kevin. 2020. Introduction: An Endless Spiral of Connectivity?. Pp. 1-10 in *After the Digital Tornado: Networks, Algorithms, Humanity*, edited by Kevin Werbach. Cambridge: Cambridge University Press.

Legal Framework for Judgement Health Data Re-use after the Case on NHI Research Database:

Lessons from EU Regulations
and the British Experience

*Wesley Yi-Hung Weng**

Abstract

This article examines the principles and implications underlying health data governance laws, and advises against abandoning Taiwan's current implementations that adopt the European Union (EU) framework for data protection and governance. The EU framework, which is widely implemented and has had a large influence in shaping international practice, provides a sound balance between safeguarding health data and enabling scientific research. While often perceived as overly complex, it provides a coherent and robust regulatory approach for balancing the rights and interests of diverse stakeholders in health data research within a comprehensive legal framework.

In contrast, the United Kingdom's (UK) efforts to enable the reuse of health data for scientific research has been fraught with challenges. The main problem lies in the lack of sufficient trust between the government and the public, particularly regarding issues on information privacy and security, data utilisation transparency, and data control. To address this, the UK has proposed Trusted Research Environments (TREs) as a solution. This approach emphasizes the need to establish "provable and trustworthy" methods for protecting privacy and data

* Professor, College of Law, Shih Hsin University.

utilisation, with one of the prerequisites being that those who use data and regulate such sharing behavior are trustworthy.

In the case of Taiwan's National Health Insurance Research Database, this article argues that current laws rely on outdated distinctions between academic research and public welfare to balance personal data rights and public interest. This approach fails to truly reflect the risks to personal data rights and make a substantive judgment based on the proportionality principle. Looking ahead, Taiwan's approach to data governance must promote institutional accountability and trust, strengthen the ability of relevant agencies to effectively supervise and manage oversight of personal data applications, and foster communication with the public.

KEYWORDS: data governance, Personal Data Protection, National Health Insurance Research Database (NHIRD), GDPR, right to privacy, trusted research environment (TRE).